

《网络攻防原理与技术（第3版）》

课后习题参考答案

1.6 习题

一、单项选择题

C=Confidential 机密性
I=Integrity 完整性
A=availability 可用性

1. 安全属性“CIA”不包括（ D ）。

A. 完整性 B. 机密性 C. 可用性 D. 可控性

2. 属于被动攻击的是（ B ）。

A. 中断 B. 截获 C. 篡改 D. 伪造

3. 下列攻击中，主要针对可用性的攻击是（ A ）。

A. 中断 B. 截获 C. 篡改 D. 伪造

4. 下列攻击中，主要针对完整性的攻击是（ C ）。

A. 中断 B. 截获 C. 篡改 D. 伪造

5. 下列攻击中，主要针对机密性的攻击是（ B ）。

A. 中断 B. 截获 C. 篡改 D. 伪造

6. 元属性“可用性”不包括的子属性是（ D ）。

A. 可靠性 B. 稳定性 C. 可生存性 D. 可控性

7. 信息在传送过程中，如果接收方接收到的信息与发送方发送的信息不同，则信息的（ C ）遭到了破坏。

数字签名可以解决伪造、抵赖、冒充和篡改问题。

A. 可用性 B. 不可否认性 C. 完整性 D. 机密性

8. 通信过程中，如果仅采用数字签名，不能解决（ D ）。

A. 数据的完整性 B. 数据的抗抵赖性 C. 数据的防篡改 D. 数据的保密性

10. 数字签名主要解决操作的（ C ）。

A. 可控性 B. 机密性 C. 不可否认性 D. 可用性

11. 重放攻击破坏了信息的（ C ）。

重放攻击主要用于身份认证过程，破坏认证的正确性。

A. 机密性 B. 可控性 C. 可鉴别性 D. 可用性

12. ISO 7498-2 从体系结构的角度描述了 5 种可选的安全服务，以下不属于这 5 种安全服务的是（ D ）。

ISO7498-2标准包括五类安全服务以及提供这些服务所需要的八类安全机制。
ISO7498-2确定的五大类安全服务，即鉴别服务、访问控制服务、数据保密性服务、数据完整性服务和禁止否认服务。
ISO7498-2标准确定的八大类安全机制，即：加密机制、数字签名机制、访问控制机制、数据完整性机制、鉴别交换机制、业务填充机制、路由控制机制和公证机制。

A. 数据完整性 B. 身份鉴别 C. 授权控制 D. 数据报过滤

13. ISO 7498-2 描述了 8 种特定的安全机制，这 8 种安全机制是为 5 类特定的安全服务设置的，以下不属于这 8 种安全机制的是（ B ）。

A. 加密机制 B. 安全标记机制 C. 数字签名机制 D. 访问控制机制

14. ISO 7496-2 从体系结构的角度描述了 5 种普遍性的安全机制，这 5 种安全机制不包括（ D ）。

A. 可信功能度 B. 安全标记 C. 事件检测 D. 数据完整性机制

15. ISO/OSI 安全体系结构中的通信对象认证安全服务，使用（ C ）机制来完成。

A. 访问控制 B. 加密 C. 数字签名 D. 数据完整性

16. 身份鉴别是安全服务中的重要一环，以下关于身份鉴别的叙述不正确的是（ B ）。

A. 身份鉴别是授权控制的基础

B. 身份鉴别一般不用提供双向认证

身份认证：单向认证与双向认证过程；通信的双方只需要一方被另一方鉴别身份，这样的认证过程就是一种单向认证。通信的双方需要互相认证鉴别对方的身份，这样的认证过程是双向认证

C. 目前一般采用基于对称密钥加密或公开密钥加密的方法

D. 数字签名机制是实现身份鉴别的重要机制

17. 信息在传送过程中，通信量分析破坏了信息的（ D ）。

A. 可用性 B. 不可否认性 C. 完整性 D. 机密性

18. P2DR 模型中的“D”指的是（ B ）。

P2DR模型是TCSEC模型的发展，也是目前被普遍采用的安全模型。P2DR模型包含四个主要部分：Policy(安全策略)、Protection(防护)、Detection(检测)和Response(响应)

APT攻击即高级可持续威胁攻击,也称为定向威胁攻击,指某组织对特定对象展开的持续有效的攻击活动。(震网病毒攻击伊朗核电站)
APT是黑客以窃取核心资料为目的,针对客户所发动的网络攻击和侵袭行为,是一种蓄谋已久的“恶意商业间谍威胁”。这种行为往往经过长期的经营与策划,并具备高度的隐蔽性。APT的攻击手法,在于隐匿自己,针对特定对象,长期、有计划性和组织性地窃取数据,这种发生在数字空间的偷窃资料、搜集情报的行为,就是一种“网络间谍”的行为。
APT攻击是一个集合了多种常见攻击方式的综合攻击。综合多种攻击途径来尝试突破网络防御,通常是通过Web或电子邮件传递,利用应用程序或操作系统的漏洞,利用传统的网络保护机制无法提供统一的防御。除了使用多种途径,高级定向攻击还采用多个阶段穿透一个网络,然后提取有价值的信息,这使得它的攻击更不容易被发现。

A. 策略 B. 检测 C. 保护 D. 恢复

19. 下列攻击方式中,最能代表网络战攻击水平的是(B)。 P19介绍了APTs攻击

A. 口令破解 B. APT 攻击 C. 缓冲区溢出攻击 D. 网络监听

20. 下列安全技术中,不属于第二代安全技术的是(D)。 P9

A. 防火墙 B. 入侵检测技术 C. 虚拟专用网 D. 可生存技术

PKI也是第二代安全技术

二、多项选择题

1. 以保护信息为主的安全元属性包括(AC)。

A. 机密性 B. 可控性 C. 可鉴别性 D. 可用性

2. 以保护信息系统为主的安全元属性包括(BD)。

A. 机密性 B. 可控性 C. 可鉴别性 D. 可用性

3. 机密性主要通过(AB)来保证。

A. 加密机制 B. 访问控制控制 C. 安全标记 D. 公证机制

4. 网络空间(Cyberspace)要保护的核心对象中,在技术层面反映“网络(Cyber)”属性的对象包括(AD)。

A. 设施 B. 用户 C. 操作 D. 数据

5. 网络空间(Cyberspace)要保护的核心对象中,在社会层面反映“空间(space)”属性的对象包括(BC)。

A. 设施 B. 用户 C. 操作 D. 数据

6. P2DR 模型中,“P2”指的是(BD)。

A. 检测 B. 保护 C. 响应 D. 策略

7. IATF 定义的与信息安全有关的核心要素包括(BCD)。 信息保障技术框架

A. 策略(Policy) B. 人(People) C. 技术(Technology) D. 操作(Operation)

8. 人为的恶意攻击分为被动攻击和主动攻击,在以下的攻击类型中属于主动攻击的是(BC)。 主动攻击包括对数据流的篡改或产生某些假的数据流

A. 网络监听 B. 数据篡改及破坏 C. 身份假冒 D. 数据流分析

9. 元安全属性“可用性”主要包括以下安全属性(ABCD)。

A. 可靠性 B. 稳定性 C. 可维护性 D. 可生存性

10. 元安全属性“可鉴别性”主要包括以下安全属性(ABC)。

A. 完整性 B. 真实性 C. 不可抵赖性 D. 稳定性

11. 数据源认证服务需要使用的安全机制包括(AB)。

A. 加密 B. 数字签名 C. 访问控制 D. 认证交换

12. 对等实体认证需要使用的安全机制包括(ABD)。

A. 加密 B. 数字签名 C. 访问控制 D. 认证交换

13. 通信业务流机密性服务需要使用的安全机制包括(BCD)

A. 访问控制 B. 加密 C. 流量填充 D. 路由控制

14. 不可抵赖服务需要使用的安全机制包括(ACD)。

A. 数字签名 B. 加密 C. 认证交换 D. 公证

15. 数据完整性服务需要使用的安全机制包括(BCD)。

A. 流量填充 B. 加密 C. 数字签名 D. 数据完整性

16. 数字签名可保护的安全属性包括(ABD)。

A. 真实性 B. 不可抵赖性 C. 机密性 D. 完整性

数据机密性服务:使得攻击者想从某个数据项中推出敏感信息是困难的;
业务流机密性服务:使得攻击者想通过观察网络的业务流来获得敏感信息是困难的。
为了防止通过监视传送数据的长度来获取信息,一般采用数据填充技术。数据填充和加密机制往往结合在一起使用来保护数据不被泄露。

三、简答题

机密性 (Confidentiality) 指信息只能为授权者使用而不泄漏给未经授权者的特性。
完整性 (Integrity) 指保证信息在存储和传输过程中未经授权不能被改变的特性。
可用性 (Availability) 指保证信息和信息系统随时为授权者提供服务的有效特性。
可控性 (Controllability) 指授权实体可以控制信息系统和信息使用的特性。
不可否认性 (Non-Repudiation) 指任何实体均无法否认其实施过的信息行为的特性，也称为抗抵赖性。

1. 简述“网络空间安全”的发展过程。

答：略。

2. 查阅资料，简要分析各国网络战部队的建设情况。

答：略。

3. 网络或信息系统的安全属性有哪些？简要解释每一个安全属性的含义。

答：建议采用方滨兴院士的观点来回答。

4. 有人说只要我有足够多的钱，就可以采购到自己想要的安全设备来保障本单位的网络安全不受攻击。你是否同意这一说法，为什么？

答：不同意。安全不仅仅是技术（对应到安全设备）上的问题，还涉及人和管理。此外，没有一种技术能完全阻止所有攻击，特别是一些未知攻击。

5. 简要分析“黑客”概念内涵的演变过程。

答：略。

6. 有人说“人是网络安全中最薄弱的环节”，谈谈你的看法。

答：略。

7. 简述“网络”与“网络空间”之间的区别与联系。

答：略。参考 1.2.1 节。

8. 假定你是本单位的安全主管，为了提高本单位的网络安全，在制定单位的安全保障方案时，有哪些措施（包括技术和非技术的）？

答：采用 IATF 类似的思想。从三个方面考虑：

（1）组织管理体系，包括：组织机构，人员编制，职责分工，教育培训；

（2）技术标准体系，包括：技术法规，标准、规范；

（3）技术防护体系，包括：P2DR 模型中涉及的各项技术。要列出常见的技术防护手段，边界部署防火墙，内部安全 IDS；单机防护（个人防火墙，杀毒软件，口令，关闭不必要的服务）；网络隔离等。

9. 比较分析“cyberspace”不同定义的异同（至少选取 3 个不同时期、不同国家或不同人给出的定义）。

答：略。参考 1.2.1 节。

10. 在 P2DR 安全模型中，假设攻击时间是 100 个单位时间，检测时间是 40 个单位时间，响应时间要满足什么条件，被防护的系统才是安全的？并给出计算过程。

答：因为系统暴露时间 $E_t = D_t + R_t - P_t$ ，如果 $E_t \leq 0$ ，那么基于 P2DR 模型，认为系统安全。 $E_t = D_t + R_t - P_t \leq 0$ ，即响应时间 $R_t \leq P_t - D_t = 100 - 40 = 60$ 个时间单位，系统才是安全的。

11. 简述你认为网络攻防人员应遵循的道德准则。

答：略。

12. 简述访问控制机制能够实现的安全目标。

答：机密性和可用性。

13. 简述安全机制与安全服务的区别与联系。

答：安全机制是指用来检测、阻止攻击或者从攻击状态恢复到正常状态的过程（或实现该过程的设备、系统、措施或技术），安全服务则是指加强数据处理系统和信息传输的安全性的处理过程或通信服务。联系：安全服务需要通过一种或多种安全机制对攻击进行反制来实现。

2.8 习题

一、单项选择题

1. 数据加密标准 DES 采用的密码类型是 (B)。
A. 序列密码 B. 分组密码 C. 散列码 D. 随机码
2. 以下几种密码算法, 不属于对称密钥密码算法的是 (C)。
A. DES B. 3DES C. RSA D. AES
3. 密码分析者只知道一些消息的密文, 试图恢复尽可能多的消息明文, 在这种条件下的密码分析方法属于 (A)。
A. 唯密文攻击 B. 已知明文攻击 C. 选择明文攻击 D. 选择密文攻击
4. “公开密钥密码体制”的含义是 (C)。
A. 将所有密钥公开 B. 将私有密钥公开, 公开密钥保密
C. 将公开密钥公开, 私有密钥保密 D. 两个密钥相同
5. 现代密码系统的安全性取决于对 (A)。
A. 密钥的保护 B. 加密算法的保护
C. 明文的保护 D. 密文的保护
6. 目前公开密钥密码主要用来进行数字签名, 或用于保护传统密码的密钥, 而不是主要用于数据加密, 主要因为 (B)。
A. 公钥密码的密钥太短 B. 公钥密码的效率比较低
C. 公钥密码的安全性不好 D. 公钥密码抗攻击性比较差
7. 若 Bob 给 Alice 发送一封邮件, 并想让 Alice 确信邮件是由 Bob 发出的, 则 Bob 应该选用 (D) 对邮件加密。
A. Alice 的公钥 B. Alice 的私钥
C. Bob 的公钥 D. Bob 的私钥
8. RSA 密码的安全性基于 (C)。
A. 离散对数问题的困难性 B. 子集和问题的困难性
C. 大的整数因子分解的困难性 D. 线性编码的解码问题的困难性
9. 把明文中的字母重新排列, 字母本身不变, 但位置改变了这样编成的密码称为 (B)。
A. 代替密码 B. 置换密码 C. 代数密码 D. 仿射密码
10. 根据密码分析者所掌握的分析资料的不同, 密码分析一般可分为4类: 唯密文攻击、已知明文攻击、选择明文攻击、选择密文攻击, 其中破译难度最大的是 (D)。
A. 唯密文攻击 B. 已知明文攻击 C. 选择明文攻击 D. 选择密文攻击
11. 下列密码算法中, 采用非对称密钥的是 (D)。
A. DES B. AES C. IDEA D. RSA
12. 下列密码算法中, 安全性依赖于离散对数难解的是 (B)。
A. AES B. Diffie-Hellman 算法 C. RSA D. DES
13. 在 RSA 的公钥密码体制中, 假设公钥为 $(e, n) = (13, 35)$, 则私钥 d 等于 (B)。
A. 11 B. 13 C. 15 D. 17
14. 计算和估计出破译密码系统的计算量下限, 利用已有的最好方法破译它所需要的代价超出了破译者的破译能力 (如时间、空间、资金等资源), 那么该密码系统的安全性是 (B)。
A. 无条件安全 B. 计算安全 C. 可证明安全 D. 实际安全
15. Diffie-Hellman 密钥交换算法的安全性依赖于 (A)。
A. 计算离散对数的难度 B. 大数分解难题 C. 算法保密 D. 以上都不是

16. 在具有层次结构的组织中, 最合适的多个 CA 的组织结构模型是(B)。
- A. 森林模型 B. 树模型 C. 瀑布模型 D. 网状模型
17. 在非层次结构的组织中, 实现多个 CA 之间交叉认证方法不包括(D)。
- A. 由用户自己决定信任哪个 CA (用户) 或拒绝哪个 CA (用户)
- B. 各 PKI 的 CA 之间互相签发证书
- C. 由桥接 CA 控制的交叉认证
- D. 上级给下级签发证书
18. 在数字证书中加入公钥所有人信息的目的是 (C)。
- A. 确定私钥是否真的隶属于它所声称的用户
- B. 方便计算公钥对应的私钥
- C. 确定公钥是否真的隶属于它所声称的用户
- D. 为了验证证书是否是伪造的
19. PKIX 标准中, 支持用户查询和下载数字证书的协议的是 (C)。
- A. TCP B. HTTP C. LDAP D. OSCIP
20. PKI 体系中, 负责产生、分配并管理证书的机构是 (D)。
- A. 用户 B. 业务受理点 C. 注册机构 RA D. 签证机构 CA
21. 散列函数具有单向性是指 (B)。
- A. 对于任意给定的 x , 计算 $H(x)$ 比较容易。
- B. 对任意给定的散列值 h , 找到满足 $H(x) = h$ 的 x 在计算上是不可行的。
- C. 对任意给定的数据块 x , 找到满足 $y \neq x$ 且 $H(x) = H(y)$ 的 y 在计算上是不可行的。
- D. 找到任意满足 $H(y) = H(x)$ 的偶对 (x, y) 在计算上是不可行的。
22. 通信过程中, 如果仅采用数字签名, 不能解决 (D)。
- A. 数据的完整性 B. 数据的抗抵赖性 C. 数据的防篡改 D. 数据的保密性
23. 数字签名通常要先使用单向哈希函数进行处理的原因是(C)。
- A. 多一道加密工序使密文更难破译
- B. 提高密文的计算速度
- C. 缩小签名消息的长度, 加快数字签名和验证签名的运算速度
- D. 保证密文能正确还原成明文
24. 现代密码学中很多应用包含散列运算, 下列应用中不包含散列运算的是(A)。
- A. 消息加密 B. 消息完整性保护 C. 消息认证码 D. 数字签名
25. 若小张给小李发送一封邮件, 并想让小李确信邮件是由小张发出的, 则小张应该选用 (D) 对邮件内容加密。
- A. 小李的公钥 B. 小李的私钥 C. 小张的公钥 D. 小张的私钥

二、简答题

1. 请简要分析密码系统(密码体制)的五个组成要素。

答: $S = \{M, C, K, E, D\}$ 。进一步解释每个组成部分。

2. 对于密码系统, 基于算法保密的策略有什么不足之处?

答: 首先, 算法泄密的代价高。加解密算法的设计非常复杂, 一旦算法泄密, 重新设计往往需要大量的人力、财力投入, 而且时间较长。其次, 不便于标准化。每个用户单位使用自己独立的加解密算法, 不可能采用统一的软硬件产品进行加解密操作。第三, 不便于质量控制。密码算法的开发, 要求有优秀的密码专家, 否则密码系统的安全性难于保障。

3. 简述密码系统的设计要求。

答：系统即使达不到理论上不可破解，也应当在实际上不可破解的；系统的保密性不依赖于加密体制或算法的保密，而依赖于密钥的保密；加密算法和解密算法适用于密钥空间中的所有元素；密码系统既易于实现也便于使用。

4. 简述分组密码的工作原理。

答：将明文以固定长度划分为多组，加密时每个明文分组在相同密钥的控制下，通过加密运算产生与明文分组等长的密文分组。解密操作也是以分组为单位，每个密文分组在相同密钥的控制下，通过解密运算恢复明文。

5. 请简要评述以 DES 为代表的对称密钥密码系统的优点和缺点。

答：优点：对称密钥密码系统具有很高的安全性，而且，无论密码系统是以硬件实现还是以软件实现，加、解密的速度都很快。缺点：通信双方为了约定密钥往往需要付出高昂代价；在加解密涉及到多人时需要的密钥量大，管理困难。

6. 请简要评述以 RSA 为代表的公开密钥密码系统的优点和缺点。

答：优点：可以解决对称密钥密码系统密钥分发困难的问题，密钥管理简单。缺点：加密操作和解密操作的速度比对称密钥密码系统慢很多。

7. 考虑 RSA 密码体制：设 $n=35$ ，已截获发给某用户的密文 $C=10$ ，并查到该用户的公钥 $e=5$ ，求出明文 M 。

解：

分解 $n=35=7\times 5$ ，于是 $p=7, q=5$ 。 $\phi(n)=6\times 4=24$ 。因为 $e=5$ ，根据 $ed=1\pmod{\phi(n)}$ ，求出 $d=5$ 。

根据 $M=C^d\pmod{n}$ ， $M=10^5\pmod{35}$ ，求出 $M=5$ 。

8. 考虑 RSA 密码体制：令 $p=3, q=11, d=7, m=5$ ，给出密文 C 的计算过程。

解： $n=3\times 11=33$ ； $\phi(n)=2\times 10=20$ ；因为 $d=7$ ，根据 $ed=1\pmod{\phi(n)}$ ，求出 $e=3$ ；

$C=m^e\pmod{n}=5^3\pmod{33}=26$

9. 对于 RSA 数字签名体制，假设 $p=839, q=983, n=p\times q=824737$ 。已知私钥 $d=132111$ ，计算公钥 e 和对消息 $m=23547$ 的签名。

解：由 RSA 签名体制可以得 $e=d^{-1}\pmod{\phi(n)}=132111^{-1}\pmod{822916}=26959$ ，对消息 m 的签名为 $s=m^d\pmod{n}=23547^{132111}\pmod{824737}=266749$ 。

10. 对于 RSA 数字签名体制，假设模 $n=824737$ ，公钥 $e=26959$ 。

(1) 已知消息 m 的签名是 $s=8798$ ，求消息 m 。

(2) 数据对 $(m, s)=(167058, 366314)$ 是有效的(消息, 签名)对吗？

(3) 已知两个有效的消息签名对 $(m, s)=(629489, 445587)$ 与 $(m', s')=(203821, 229149)$ ，求 $m\times m'$ 的签名。

解：

(1) 由公式可得： $m=s^e\pmod{n}=8798^{26959}\pmod{824737}=123456$ 。

(2) 因为 $m'=s^e\pmod{n}=366314^{26959}\pmod{824737}=167058=m$ ，所以是有效的(消息, 签名)对。

(3) $m\times m'$ 的签名 $= (m\times m')^d\pmod{n}=s\times s'\pmod{n}=445587\times 229149\pmod{824737}=75915$ 。

11. 设 H 是一个安全的哈希函数，Alice 将消息和其哈希值 $M\parallel H(M)$ 一并发送，以检测消息是否在传输过程中被篡改，问：这样做可否达到 Alice 的安全目标？为什么？

答：不能，因为 Hash 函数本身没有密钥，给定 M ，任何人（包括攻击者）都可以正确

计算出其哈希值，所以攻击者可以将 Alice 发送的消息 M 修改为 M' ，并计算 $H(M')$ ，而接收方无法确定原始消息的完整性。

12. 有了公钥证书，为什么还需要 PKI?

答：有了证书以后，就会涉及证书的申请、发布、查询、撤销等一系列管理任务，因此需要一套完整的软硬件系统、协议、管理机制来完成这些任务，这就是公钥基础设施(PKI)。

13. 简要说明 PKI 系统中多个 CA 间建立信任的方法。

答：1) 对于具有层次结构的组织，可采用树型信任模型；

2) 双向交叉认证证书，包括：① 各 PKI 的 CA 之间互相签发证书，从而在种局部 PKI 之间建立起了信任关系；② 由用户控制的交叉认证，即由用户自己决定信任哪个 CA 或拒绝哪个 CA；③由桥接 CA 控制的交叉认证；

3) 以用户为中心的信任模型 (User Centric Trust Model)。在这种模型中，每个用户自己决定信任其他哪些用户。

14. 请解释什么是密钥管理问题，密钥管理对于对称密钥密码系统有什么意义。

答：密钥管理包括密钥的产生、存储、分发、组织、使用、停用、更换、销毁等一系列问题，涉及每个密钥的从产生到销毁的整个生命周期。现代密码学一般采用基于密钥保护的安全策略来保证密码系统的安全，因此对密钥的保护关乎整个通信的安全保密。如果任何一个环节出现问题，均可能导致密钥的泄露，进而导致泄露。

15. 比较分析唯密文攻击、已知明文攻击、选择明文攻击、选择密文攻击等四种密码攻击方法的破解思路和破解难度。

答：唯密文攻击：攻击者手中除了截获的密文外，没有其他任何辅助信息，难度最大；

已知明文攻击：攻击者除了掌握密文，还掌握了部分明文和密文的对应关系；

选择明文攻击：攻击者知道加密算法，同时能够选择明文并得到相应明文所对应的密文；

选择密文攻击：攻击者知道加密算法，同时可以选择密文并得到对应的明文，攻击者的攻击目标通常是加密所使用的密钥。

3.6 习题

一、单项选择题

- 下面有关 ARP 协议的描述中，(B) 是错误的。
A. ARP 欺骗只能被用于本地网络
B. ARP 欺骗可在本地网络以外成功使用
C. ARP 协议可被用来进行拒绝服务攻击
D. 一般情况下，当主机收到 ARP 请求或响应时，需要刷新其 ARP 缓存
- 下列认证方式中，不属于 OSPF 协议定义的认证方法是 (D)。
A. NULL 认证 B. 简单口令认证 C. MD5 加密认证 D. SHA1 加密认证
- 2011 年出现的一种针对路由协议的攻击方法，俗称“数字大炮”，这种攻击利用路由器正常工作过程中路由表更新机制，通过在网络上制造某些通信链路的时断时续的震荡效应，导致网络中路由器频繁地更新路由表，最终当网络上震荡路径数量足够多、震荡频率足够高时，网络上所有路由器都处于瘫痪状态。该攻击利用了 (C) 路由协议存在的安全缺陷。
A. RIP B. OSPF C. BGP D. IGRP
- 攻击者在攻击一个目标时，经常用伪造的 IP 地址来发送攻击数据包（数据包的源 IP 地址是伪造的），这样做之所以能成功，主要原因是 (A)。
A. 路由器在转发 IP 包时不检查 IP 源地址
B. 路由器在转发 IP 包时检查 IP 源地址
C. 路由器在转发 IP 包时检查 IP 目的地址
D. 路由器在转发 IP 包时不检查 IP 目的地址
- UDP 协议可被攻击者用来进行 (B)。
A. 监听 B. 风暴型拒绝服务攻击 C. 连接劫持 D. 传播木马
- TCP 协议报文中，与 TCP 连接建立和释放过程无关的标志位是 (D)。
A. SYN B. FIN C. ACK D. URG
- 互联网中大量存在的“中间盒子”不符合互联网设计之初提出的 (A) 原则，导致了大量网络攻击事件的发生。
A. 端到端 B. 尽力而为 C. 分组交换 D. 分层设计
- 下列路由协议中，安全性最高的是 (B)。
A. RIPv1 B. RIPv2 C. RIPv3 D. 所有版本的 RIP 协议
- 下列路由协议中，使用 TCP 作为传输协议的是 (C)。
A. RIP B. OSPF C. BGP D. RIPv2
- 下列交换方式中，最容易被攻击的是 (A)。
A. 分组交换 B. 电路交换 C. 专线 D. 报文交换

二、多项选择题

- 很多单位的安全管理员会在防火墙的设置中禁用因特网控制管理协议 (ICMP)，主要原因是攻击者常常使用 ICMP 进行 (ABC)。
A. 拒绝服务攻击 B. 隐蔽通信 C. 主机扫描 D. 会话劫持
- TCP 协议可被攻击者用来进行 (ABC)。
A. 拒绝服务攻击 B. 连接劫持 C. 网络端口扫描 D. 网络监听
- IP 协议可以被攻击者用来进行 (ABC)。
A. 拒绝服务攻击 B. 源路由攻击 C. 绕过防火墙 D. 网络端口扫描
- 下列协议中，使用 UDP 作为传输协议的是 (BCD)。
A. TCP B. DNS C. DHCP D. TFTP

A. FTP B. DNS C. SNMP D. RIP

5. DNS 协议易遭受的网络攻击包括（ ABC ）。

A. 缓存投毒 B. 拒绝服务攻击 C. 域名解析劫持 D. 溢出攻击

6. Web 浏览器和服务器使用 HTTPS 协议进行通信，可确保通信的（ ABD ）。

A. 机密性 B. 完整性 C. 可靠性 D. 服务器的真实性

7. 下列攻击中，针对 OSPF 协议的攻击包括（ ABCD ）。

A. 篡改 IP 包中的协议字段 B. 最大年龄（Max Age attack）攻击

C. 最大序列号攻击 D. LSA 报文重放攻击

三、简答题

1. 从体系结构上讲，因特网有哪些不足之处？

答：分组交换易被攻击；缺少有效的认证机制；尽力而为(best-effort)的服务策略；匿名与隐私；对全球网络基础设施的依赖；无尺度网络；互联网的级联特性；中间盒子。

2. TCP 协议的哪些字段或特性可被攻击者利用？

答：TCP 协议的标志位 SYN, FIN, RST, ACK 等字段，TCP 的有连接特性，可用于进行网络扫描、连接劫持、拒绝服务攻击。

3. IP 协议的哪些字段或特性可被攻击者利用？

答：IPv4 协议的无连接、无认证、无加密、无带宽控制等特性，可被攻击者利用来伪造或篡改 IP 包、监听、拒绝服务等攻击。

IPv6 协议的不足：对于同时支持 IPv4 和 IPv6 的主机，黑客可以利用这两种协议中存在的安全弱点和漏洞进行协调攻击，或者利用两种协议版本中安全设备的协调不足来逃避检测；无状态地址自动配置的安全风险；IPv6 中 PKI 管理系统的安全风险；IPv6 编址机制的隐患；IPv6 的安全机制给网络安全体系所带来的安全风险。

4. ARP 协议的哪些字段或特性可被攻击者利用？

答：ARP 协议对收到的 ARP 响应不作任何验证就更新其 ARP 缓存，即允许未经请求的 ARP 广播或单播对缓存中的 IP-MAC 对应表项进行删除、添加或修改，可导致以下攻击：网络监听，攻击者可以伪造 ARP 响应，从本地或远程发送给主机，修改 ARP 缓存，从而重定向 IP 数据流到攻击者主机，达到窃听、假冒或拒绝服务（如，IP 地址冲突、网络数据包定向到非目的主机）的目的；阻止目标的数据包通过网关。

5. ICMP 协议的哪些字段或特性可被攻击者利用？

答：不管 ICMPv4 还是 ICMPv6，ICMP 协议本身的特点决定了它非常容易被用于攻击网络上的路由器和主机，包括：

（1）利用“目的不可达”报文对攻击目标发起拒绝服务攻击。

（2）利用“改变路由”报文破坏路由表，导致网络瘫痪。

（3）木马利用 ICMP 协议报文进行隐蔽通信。

（3）利用“回送(Echo)请求或回答”等询问报文进行网络扫描或拒绝服务攻击。

6. 路由器为什么不提供数据追踪功能？

答：数据量太大，路由器没有哪么大的存储和处理能力。另外，如果实现数据追踪功能会严重影响路由器性能。

7、在某大型计算机网络的网络管理部门中，对于 ICMP 协议存在两种观点：一种观点认为应该关闭 ICMP 协议（如，用防火墙过滤掉 ICMP 协议报文），而另一种观点则认为应该保留。试给出他们各自的依据。

答：（1）关闭 ICMP 协议的理由：ICMP 协议带来了大量的安全问题，如使用 ICMP 协议来进行主机探测、操作系统识别；利用 ICMP 的改变路由报文欺骗主机将报文发送到攻击

主机；使用 ICMP 进行拒绝服务攻击等。

(2) 保留 ICMP 协议的理由：设计 ICMP 协议的目的是为了提高 IP 数据报交付成功的机会，帮助网络管理人员了解网络中当前的运行状态。

8. 美国《纽约客》杂志曾以黑色幽默方式指出互联网存在的问题——“在互联网上，没有人知道你是一条狗”。谈谈你对这个幽默的看法。

答：略。

9. 有人说“所有破坏网络或信息系统的安全均是人为故意造成的”。你认同这种说法？为什么？

答：不同意。有些安全问题是无意造成的，如配置错误、自然因素造成的。

10. 有系统设计人员给客户保证说“我们考虑得很周到，设计的系统没有任何问题，可以阻止任何攻击，你们可以放心使用”。请分析这种说法存在的问题。

答：设计没有问题，并不表明实现也没有问题。即使实现没问题，使用过程中也可能存在问题。

11. 简述软件后门与漏洞的区别。

答：软件后门是人为故意留下的，而漏洞是无意留下的。

12. 操作系统是如何防止不同应用程序之间、应用程序与操作系统之间相互被影响的？

答：操作系统使用内核态和用户态来防止应用各种与操作系统之间相互影响。为每个应用程序分配独立的内存空间，相互隔离来防止应用程序之间相互影响。

13. 简述可能导致软件安全漏洞出现的原因。

答：1) 方案的设计可能存在缺陷。

2) 从理论上证明一个程序的正确性是非常困难的。

3) 一些产品测试不足，匆匆投入市场。

4) 为了缩短研制时间，厂商常常将安全性置于次要地位。

5) 系统中运行的应用程序越来越多，相应的漏洞也就不可避免地增多。

6) 现代软件生产方式带来的安全问题。

7) 软件的高复杂度。

14. 如何看待软件补丁在解决软件安全漏洞问题中的作用？

答：很重要，但不是万能。详细分析参考 3.5 节。

4.5 习题

一、单项选择题

1. 攻击者如果想查找互联网上某个地方的联网摄像头,最合适的搜索引擎是(B)。
A. 百度 B. ZoomEye C. 360 搜索引擎 D. 搜狗
2. 如果在百度上用关键词查找符合要求的 Word 文件,则应使用的百度命令是(A)。
A. filetype B. site C. Inurl D. index
3. 下列词当中,不属于 Shodan 搜索引擎网络服务类过滤词的是(D)。
A. net B. port C. os D. ip
4. 如果要查询 nju.edu.cn 是在哪个域名注册机构注册的,最合适的 Whois 数据库是(A)。
A. CNNIC 的 Whois 数据库 B. InterNIC 的 Whois 数据库
C. IANA 的 Whois 数据库 D. RIPE 的 Whois 数据库
5. 如果要查询 yahoo.com 是在哪个域名注册机构注册的,最合适的 Whois 数据库是(B)。
A. CNNIC 的 Whois 数据库 B. InterNIC 的 Whois 数据库
C. IANA 的 Whois 数据库 D. RIPE 的 Whois 数据库
6. 如果要查询美国哈佛大学校园内的一个 IP 地址的相关信息,最合适的 Whois 数据库是(C)。
A. RIPE 的 Whois 数据库 B. APNIC 的 Whois 数据库
C. ARIN 的 Whois 数据库 D. LACNIC 的 Whois 数据库
7. 如果要查询英国牛津大学校园内的一个 IP 地址的相关信息,最合适的 Whois 数据库是(A)。
A. RIPE 的 Whois 数据库 B. APNIC 的 Whois 数据库
C. ARIN 的 Whois 数据库 D. LACNIC 的 Whois 数据库
8. 如果要查询江苏南京某小区住户家里通过宽带接入互联网的电脑的 IP 地址的相关信息,最合适的 Whois 数据库是(B)。
A. RIPE 的 Whois 数据库 B. APNIC 的 Whois 数据库
C. ARIN 的 Whois 数据库 D. LACNIC 的 Whois 数据库
9. 如果想了解一个域名注册机构是不是合法的,则应该在(A)的网站上查询。
A. InterNIC B. APNIC C. CNNIC D. ARIN
10. 下列 Whois 数据库中,最有可能查询到一个后缀为.com 的域名的拥有者的相关信息(如联系人电话、邮箱等)的是(D)。
A. CNNIC 的 Whois 数据库 B. InterNIC 的 Whois 数据库
C. IANA 的 Whois 数据库 D. MarkMonitor Inc.的 Whois 数据库
11. 支持域名的 IP 及其所有者信息查询的是(A)。
A. Whois 数据库 B. DNS C. 目录服务 D. 搜索引擎

二、简答题

1. 想要攻击某个站点,在仅仅知道该站点域名的情况下,如何一步一步地查明该站点所用的 IP 地址、管理员的联系方式以及站点内部主机信息等资料?

答:按照下面的步骤顺序:

- (1) 查询该域名的注册机构。比如.com、.net 等域名到互联网网络信息中心的 Whois 数据库(<http://www.internic.net/whois.html>)中查询。从而找到目标的具体注册机构的 Whois 库;
- (2) 通过注册机构的 Whois 数据库,可以检索到 IP 地址、管理员的联系方式(联系人

姓名、电话号码、电子邮件、邮政地址)、注册时间、DNS 服务器地址等;

(3) 查询 IP 地址分配。一些按地理位置分配的 Whois 数据库存储了目标信息资源的 IP 地址块。比如访问美国互联网号注册局 (ARIN) 的 Whois 数据库, 可以查询到北美地区域名分配的 IP 地址块;

(4) DNS 区传送查询。基于第 2 步查询到的 DNS 服务器信息, 使用 DNS 区传送查询工具 (比如 Windows 下的 nslookup), 可以查询到目标站点内部主机的一些信息, 比如哪些主机用作邮件服务器、DNS 服务器等等。

另外, 利用第 2 步查询到的管理员联系方式、目标公司的信息等, 使用社会工程学的方式, 收集和掌握实施入侵所需要的相关资料与信息。

2. 简述网络拓扑结构在网络攻击中的作用。

答: 可以发现网络中的关键结点, 对关键结点进行攻击, 可以大大提高效率。

3. 简述网络侦察在网络攻击中的作用。

答: 了解目标, 为制定后续的渗透攻击方案提供支撑。

4. 简述百度搜索引擎常用命令的功能及使用方法。

答: 略。参考 4.2.1 节。

5. 简述网络侦察的防御方法。

答: 防御社会工程学的有效方法是培养员工的安全意识, 在安全教育时强调社会工程学方面的知识; 防御垃圾搜索的最好方法是配备并合理使用碎纸机、光盘粉碎机等设备, 对于安全性要求高的机构 (例如政府安全部门和军事单位), 还需要由保密部门对办公废弃物进行统一处理; 对域名注册、IP 地址等信息进行保密处理, 如要求在 Whois 数据库查询时不显示相关信息。

6. 某次网络作战行动的目标是一个敌对组织的 Web 网站, 为了制定后续攻击方案, 请为这次攻击行动制定一个网络侦察方案。

答: 此题答题要点与第 1 题类似。还可以增加一条: 浏览该网站, 从网站上寻找有价值的信息, 如组织简介、电话、办公地址、工作业务、合作伙伴、相关链接等。

5.6 习题

一、单项选择题

1. 对于 TCP SYN 扫描, 如果发送一个 SYN 标志置 1 的请求包后, 对方返回(B) 的响应包则表明目标端口处于打开状态。
A. ACK 标志置 1 B. SYN 和 ACK 标志置 1
C. SYN 和 RST 标志置 1 D. RST 和 ACK 标志置 1
2. 网络扫描一般不会使用(B) 进行。
A. IP 协议 B. DNS 协议 C. TCP 协议 D. ICMP 协议
3. 为了防止网络扫描行为被网络安全系统发现, 不应当采用(C) 策略。
A. 随机端口扫描 B. 分布式扫描 C. 连续端口快速扫描 D. 伪造源地址
4. 端口扫描的主要功能是(A)。
A. 探测目标主机上开放了哪些网络服务
B. 探测主机是否开机
C. 识别操作系统的类型
D. 判断目标主机上是否存在某个已公开的漏洞
5. 漏洞扫描能够识别的漏洞类型是(A)。
A. 已知漏洞 B. 未知漏洞 C. 已知漏洞和未知漏洞 D. 所有漏洞
6. 下列扫描方式中, 使用 ICMP 协议的是(D)。
A. TCP FIN 扫描 B. TCP SYN 扫描 C. 漏洞扫描 D. ping 扫描

二、多项选择题

1. 用 ping 探测目标主机, 如果得不到其响应, 可能的原因有(ABC)。
A. 目标主机没开机
B. 防火墙阻止了 ping 请求
C. 目标主机路由不可达
D. 肯定没开机
2. 可用于进行网络主机或端口扫描的 TCP/IP 协议有(ABC)。
A. TCP B. ICMP C. UDP D. ARP
3. 用可用操作系统识别的特征包括(ABCD)。
A. 网络协议指纹 B. 旗标 (banner)
C. TCP 协议可选项 D. 开放网络端口信息
4. TCP SYN 扫描中, 利用的标志位包括(ABD)。
A. SYN B. ACK C. URG D. RST
5. 网络扫描包括(ABCD)。
A. 主机扫描 B. 端口扫描 C. 操作系统识别 D. 漏洞扫描
6. 如果 ICMP 协议被防火墙封锁, 则下列扫描方式很可能不准确(CD)。
A. TCP 全连接扫描 B. TCP SYN 扫描 C. UDP 扫描 D. ping 扫描

三、简答题

1. 主机扫描的目的是什么? 请简述主机扫描方法。

答: 主机扫描的目的是判断目标主机的工作状态, 即判断目标主机是否联网并处于开机状态。主机扫描方法主要有:

- a) 常规主机扫描: ICMP 扫射; 广播 ICMP;
- b) 非常规主机扫描: Non-ECHO ICMP; 异常的 IP 头; TCP 扫射; UDP 扫射。

2. 端口扫描的目的是什么？请简述端口扫描方法及扫描策略。

答：端口扫描的目的是判断目标主机的端口工作状态，即端口处于监听还是处于关闭的状态，进而发现主机中哪些服务是处于服务状态。

端口扫描方法包括：

a. 显示扫描方法：TCP 连接全打开；TCP 连接半打开；

b. 隐式扫描方法：SYN / ACK 扫描；FIN 扫描；XMAS 扫描；NULL 扫描；反向映射；TCP 反向 Ident 扫描；FTP 反弹扫描；

扫描策略：随机端口扫描；慢扫描；分片扫描；诱骗；分布式协调扫描。

3. ICMP 协议可以在哪些类型的网络扫描中被利用，具体如何利用？

答：常规主机扫描，ICMP Echo 报文；非常规主机扫描方法：Non-ECHO ICMP（如向某个 IP 地址发送 ICMP 的地址掩码请求，如果收到了回答，那么可以断定该 IP 地址对应于网络中的一台存活主机）；异常的 IP 头（需要用到“参数有问题”的 ICMP 差错报告报文）等。

4. 分析 TCP SYN 扫描方法的优缺点。

答：TCP SYN 扫描刻意不建立完整的 TCP 连接，以避免暴露扫描行为，隐蔽性好。缺点在于对用户权限有较高要求。要实现 TCP SYN 扫描，用户需要自己构造 TCP SYN 数据包，通常只有管理员权限的用户才能够构造此类数据包，普通权限的用户无法执行 TCP SYN 扫描。

5. 分析 TCP FIN 扫描存在的问题。

答：由于目标端口处于监听状态时不会对 TCP FIN 扫描报文做出任何回应，因此执行扫描的一方必须等待超时，增加了扫描时间，而且如果网络传输过程中扫描数据包丢失或者应答丢失的话，扫描主机也将做出错误的结论。其次，并不是所有的操作系统都遵循了 RFC 793 的规定，其中最具代表性的是微软公司的 Windows 操作系统。Windows 操作系统收到 FIN 标志位设置为 1 的报文时，相应端口无论是否开放都会回应一个 RST 标志位设置为 1 的连接复位报文。在这种情况下 TCP FIN 扫描无法发挥区分作用。此外，与 TCP SYN 扫描相同，构造 FIN 扫描报文要求用户具有较高的权限。

6. 操作系统识别的目的是什么？简述操作系统识别方法。

答：操作系统识别的目的是为发现目标系统安全漏洞作准备；

操作系统识别方法：

a) 标识提取，如 Telnet 服务信息，DNS HINFO 记录等；

b) TCP / IP 协议指纹：FIN 位、DF 位、初始序列号；初始窗大小；ACK 序号；ICMP 错误消息抑制；ICMP 消息引用；TOS 字段值；TCP 选项；TTL 值等。

7. 简述漏洞扫描对于网络安全的意义。

答：漏洞扫描对于计算机管理员和攻击者而言都有重要意义。计算机管理员希望能够通过漏洞扫描及时发现计算机的安全漏洞从而有针对性的进行安全加固。攻击者则希望利用扫描找到能够使自己获取系统访问权限甚至控制权限的安全漏洞。

8. 网络管理员出于安全防护的需要选购漏洞扫描软件，通常需要考虑哪些因素？

答：漏洞库大小，包含漏洞越多越好；支持的平台越多越好；性能等。

9. 基于网络的漏洞扫描软件 Nessus 主要包括哪些组成部分，各组成部分分别发挥哪些作用？

答：客户和服务器。客户端接收用户输入、显示扫描结果，服务器接受客户端的发出的扫描请求，依据漏洞库中的漏洞信息构造一系列扫描数据包发向指定的目标主机或目标网络，并根据返回结果判断目标中是否存在指定的安全漏洞。

6.6 习题

一、单项选择题

1. 某单位联在公网上的 Web 服务器的访问速度突然变得比平常慢很多，甚至无法访问到，这台 Web 服务器最有可能遭到的网络攻击是（ A ）。
A. 拒绝服务攻击 B. SQL 注入攻击 C. 木马入侵 D. 缓冲区溢出攻击
2. 2018 年 2 月，知名代码托管网站 GitHub 遭遇了大规模 Memcached DDoS 攻击，攻击者利用大量暴露在互联网上的 Memcached 服务器实施攻击，这种攻击最有可能属于（ B ）。
A. 直接型 DDoS B. 反射型 DDoS
C. 剧毒包型 DoS D. TCP 连接耗尽型 DDoS 攻击
3. 2016 年 10 月 21 日，美国东海岸地区遭受大面积网络瘫痪，其原因为美国域名解析服务提供商 Dyn 公司当天受到强力的 DDoS 攻击所致，攻击流量的来源之一是感染了（ C ）僵尸的设备。
A. Sinit B. Agobot C. Mirai D. Slapper
4. 拒绝服务攻击导致攻击目标瘫痪的根本原因是（ A ）。
A. 网络和系统资源是有限的 B. 防护能力弱
C. 攻击能力太强 D. 无法确定
5. 下列攻击中，不属于拒绝服务攻击的是（ D ）。
A. SYN Flood B. Ping of death C. UDP Flood D. SQL Injection
6. 下列安全机制中，主要用于缓解拒绝服务攻击造成的影响的是（ C ）。
A. 杀毒软件 B. 入侵检测 C. 流量清洗 D. 防火墙
7. 在风暴型拒绝服务攻击中，如果攻击者直接利用控制的僵尸主机向攻击目标发送攻击报文，则这种拒绝服务攻击属于（ B ）。
A. 反射型拒绝服务攻击 B. 直接型拒绝服务攻击
C. 碎片攻击 D. 剧毒包型拒绝服务攻击
8. 拒绝服务攻击除了瘫痪目标这一直接目的外，在网络攻防行动中，有时是为了（ A ），帮助安装的后门生效或提升权限。
A. 重启目标系统 B. 窃听 C. 传播木马 D. 控制主机
9. 对 DNS 实施拒绝服务攻击，主要目的是导致 DNS 瘫痪进而导致网络瘫痪，但有时也是为了（ A ）。
A. 假冒目标 DNS B. 权限提升 C. 传播木马 D. 控制主机

二、多项选择题

1. 很多单位的网络安全管理员在配置网络防火墙时，会阻止 ICMP 协议通过，这样做的主要目的是防止攻击者对单位网络实施（ BD ）。
A. 木马传播 B. 主机扫描 C. 端口扫描 D. 拒绝服务攻击
2. 反射型拒绝服务攻击在选择用作攻击流量的网络协议时，通常依据以下原则（ ABC ）。
A. 互联网上有很多可探测到的支持该协议的服务器
B. 部分协议的请求报文大小远小于响应报文的大小
C. 协议具有无连接特性
D. 协议具有有连接特性
3. DNS 经常被用作反射式 DDoS 攻击的反射源，主要原因包括（ ACD ）。
A. DNS 查询的响应包远大于请求包

- B. DNS 报文比较短
 - C. 区传送或递归查询过程中 DNS 响应报文数量远大于请求报文数量
 - D. 因特网上有很多 DNS 服务器
4. 下列攻击中，影响了目标系统可用性的有（ AC ）。
- A. 拒绝服务攻击
 - B. 网络窃听
 - C. 控制目标系统并修改关键配置使得系统无法正常运行
 - D. 在目标系统上安装后门
5. 近几年，物联网设备大量被攻击者控制，成为僵尸网络的一部分。从攻击者的角度来看，选择物联网设备作为控制对象的主要因素包括（ ABD ）。
- A. 物联网设备数量大
 - B. 物联网设备安全防护弱
 - C. 物联网设备计算能力弱
 - D. 物联网设备安全漏洞多
6. 下列协议中，可用作拒绝服务攻击的有（ ABCD ）。
- A. ICMP
 - B. HTTP
 - C. TCP
 - D. UDP
7. 下列协议中，可用作反射型拒绝服务攻击的包括是（ BD ）。
- A. UDP
 - B. SSDP
 - C. TCP
 - D. NTP
8. 当拒绝服务攻击发生时，被攻击目标的网络安全人员通常可采取的措施包括（ AB ）。
- A. 用流量清洗设备对攻击流量进行清洗
 - B. 断开网络，待攻击停止后再连通
 - C. 关机
 - D. 不采取任何措施
9. 下列选项中，可用于检测拒绝服务攻击的有（ AB ）。
- A. DoS 攻击工具的特征
 - B. 网络异常流量特征
 - C. 源 IP 地址
 - D. 目的地址

三、简答题

1. 拒绝服务攻击这种攻击形式存在的根本原因是什么，是否能完全遏制这种攻击？

答：网络和系统资源是有限的，不能完全遏制。

2. 拒绝服务攻击的核心思想是什么？

答：依靠消耗网络带宽或系统资源(如，处理机、磁盘、内存)导致网络或系统不胜负荷以至于瘫痪而停止提供正常的网络服务或使服务质量显著降低，或通过更改系统配置使系统无法正常工作(如，更改路由器的路由表)，来达到攻击的目的。

3. 简述拒绝服务攻击的检测方法。

答：略。参考 6.5.1 节。

4. 如何利用 IP 协议进行 DoS 攻击？

答：泪滴攻击（Teardrop）。

5. 如何利用 ICMP 协议进行 DoS 攻击？

答：Ping of Death；Ping Flooding。

6. 哪些协议可被攻击者用来进行风暴型 DDoS 攻击？攻击者在选择用做 DDoS 攻击流量的协议时，主要考虑哪些因素？

答：TCP，ICMP，UDP，HTTP/HTTPS、NTP、SSDP、DNS、SNMP 等协议经常被用来进行风暴性 DDoS 攻击。主要考虑：没有认证，容易伪造（如无连接特性），协议报文处理能消耗大量资源。反射型 DDoS：无连接特性，网上有大量可用作反射源的服务器，响应远

大于请求。

7. 在 6.3.5 节的攻击案例中，DNSPod 是 18 日晚被关闭的，为什么当晚没有出现网络瘫痪，而一直到第二天（19 日晚）才全面爆发？

答：DNS 缓存失效时间。

8. 分析 6.3.5 节的攻击案例，给出 DNSPod、暴风影音软件的改进方案。

答：限制重试次数和时间间隔。

9. 如何利用 DNS 进行网络攻击？设计几种可能的攻击方案。

答：略。可以用 DNS 进行反射型拒绝服务攻击或 DNS 劫持。参考 3.4.9 节。

10. 在网络攻击中，拒绝服务攻击除了用于致瘫攻击目标外，是否还可作为其他攻击的辅助手段？试举例说明。

答：SYN Flood 攻击可以用于 IP 劫持、IP 欺骗等。当攻击者想要冒充 C 跟 B 通信时，通常要求 C 不能响应 B 的消息，为此，攻击者可以先攻击 C（如果它是在线的）使其无法对 B 的消息进行响应。然后攻击者就可以通过窃听发向 C 的数据包，或者猜测发向 C 的数据包中的序列号等，然后冒充 C 与第三方通信。

一些系统在启动时会有漏洞，可以通过拒绝服务攻击使之重启，然后在该系统重启时针对漏洞进行攻击。如 RARP-boot，如果能令其重启，就可以将其攻破。

有些网络中，当防火墙关闭时允许所有数据包都能通过（特别是对于那些提供服务比保障安全更加重要的场合，如普通的 ISP），则可通过对防火墙进行拒绝服务攻击使其失去作用达到非法访问受保护网络的目的

如果攻击者已经修改了系统的管理权限，可能需要采取拒绝服务攻击的手段使系统重启或者迫使系统的真正管理员重启系统，以便使改动的配置生效。

11. 如何应对拒绝服务攻击？

答：流量清洗。

12. 简述僵尸网络有几种类型，并分析每种类型的优缺点。

答：基于 IRC 的僵尸网络，基于 P2P 的僵尸网络。前者控制简单，但可靠性差；后者控制复杂，但可靠性高，抗摧毁能力强。

13. 为了应对攻击者利用分片来穿透防火墙，防火墙在检测时进行数据包的重组，仅当重组后的数据包符合通行规则时，数据包片段才可放行。攻击者如何利用防火墙这一处理机制对防火墙进行攻击？

答：大量分片，耗尽防火墙的处理器资源，导致拒绝服务攻击。

14. 在 SYN Flood 攻击中，攻击者为什么要伪造 IP 地址？

答：防止被溯源。

15. 如何检测 SYN Flood 攻击？

答：短时间内收到大量 TCP SYN 包。

16. 分析 SYN Flood 攻击、TCP 连接耗尽型攻击、HTTP 风暴型攻击的优缺点。

答：略。参考 6.3.2 节。

17. 简述流量清洗的基本原理？并选择某一厂商的流量清洗系统为例进行分析。

答：略。参考 6.5.2 节。

四、综合题

1. 直接风暴型拒绝服务攻击与反射式风暴型拒绝服务攻击的区别是什么？有哪些网络协议被攻击者用来进行风暴型拒绝服务攻击？如果你是一个攻击者，你在选择用作风暴型拒绝服务攻击的网络协议时主要考虑哪些因素？

答：1) 直接风暴型 DDoS 与反射式风暴型 DDoS 的主要区别是否用其控制的主机直接

向受害主机发送攻击数据包，直接风暴型 DDoS 是攻击者直接向攻击目标发送大量的网络数据包，而反射型 DDoS 则是攻击者伪造攻击数据包，其源地址为被攻击主机的 IP 地址，目的地址为网络上大量网络服务器或某些高速网络服务器，通过这些服务器（作为反射器）的响应实施对目标主机的拒绝服务攻击。

2) 常见用于风暴型拒绝服务攻击的协议有：ICMP, UDP, TCP, HTTP, NTP, DNS, SSDP, CharGEN, SNMP, Memcached 等。

3) 主要有 3 点：一是协议具有无连接特性，二是互联网上有很多可探测到的支持该协议的服务器，三是该协议的部分请求报文大小远小于响应报文的大小。

7.6 习题

一、单项选择题

1. 关闭网络端口（ B ）可阻止勒索病毒 WannaCry 传播。
A. 23 B. 445 C. 115 D. 25
2. 计算机蠕虫（Worm）的主要传播途径是（ A ）。
A. 网络系统漏洞 B. 移动存储设备 C. 电子邮件 D. 宿主程序的运行
3. 同计算机木马和蠕虫相比，计算机病毒最重要的特点是（ D ）。
A. 寄生性 B. 破坏性 C. 潜伏性 D. 自我复制
4. 下列恶意代码中，传播速度最快的是（ C ）。
A. 计算机病毒 B. 计算机木马 C. 计算机蠕虫 D. 病毒和木马
5. 对木马的可执行文件 readme.exe(EXE 文件)，为了诱骗用户双击执行，下列选项中，最好的隐藏方式是（ A ）。
A. 文件全名为 readme.txt.exe，文件图标为 TXT 文档默认图标
B. 文件全名为 readme.txt，文件图标为 TXT 文档默认图标
C. 文件全名为 readme.exe，文件图标为 EXE 文件默认图标
D. 文件全名为 readme.exe.txt，文件图标为 TXT 文档默认图标
6. 下列文件类型中，感染木马可能性最小的是（ B ）。
A. exe 文件 B. txt 文件 C. doc 文件 D. ppt 文件

二、多项选择题

1. 计算机木马可通过（ ABCD ）进行传播。
A. 移动存储设备 B. 电子邮件 C. Office 文档 D. Web 网页
2. 可能会被计算机木马用作远程回传信息的方法有（ ABD ）。
A. 网盘 B. 电子邮件 C. 人工拷贝 D. 与木马控制端直接建立 TCP 连接
3. 网络钓鱼邮件附件中常用来携带木马的文档文件类型有（ ABCD ）。
A. DOC/DOCX B. PPT/PPTX C. XLS/XLSX D. PDF
4. 常用的木马启动方式包括（ ABCD ）。
A. 开机自启动 B. Windows 中的计划任务
C. 通过 DLL 启动 D. 文件浏览自动播放
5. 杀毒软件为了防止恶意代码侵入计算机，通常要监控 Windows 系统中的（ ABD ）。
A. 注册表 B. 系统文件 C. 用户的文本文件 D. Office 文档
6. 计算机木马在运行过程中的隐藏方法有（ BCD ）。
A. 正常运行 B. 木马 DLL C. 远程线程插入 D. 进程列表欺骗
7. 下列选项中，远程控制木马隐藏其通信的方式有（ ABC ）。
A. 端口复用 B. 通信内容隐藏在 ICMP 协议报文中
C. 通信内容隐藏在 HTTP 协议报文中 D. 直接建立 TCP 连接进行明文通信
8. 木马为了提高通信的隐蔽能力，通常不会采取的策略是（ ACD ）。
A. 快速将窃取的数据传回来 B. 少量多次回传窃取的数据
C. 将被控主机上所有文件全部打包回传 D. 明文传输

三、问答题

1. 请简述计算机木马与计算机病毒之间存在的相同点和不同点。

答：最主要区别在于是否能自我复制，木马不能，而病毒能。相同点都是恶意的计算机代码。

2. 远程控制型木马与远程控制软件之间存在什么区别？

答：首先，访问是否经过了授权，远程控制软件一般需要访问者输入在被访问主机上的账号和密码等信息，只有通过身份验证的用户才能进入系统，根据账户的权限进行操作，这种访问是在身份认证基础上进行的合法授权访问。而利用远程控制型木马对远程主机的访问是非授权的，木马程序在远程主机上的运行使得黑客能够在远程主机上进行文件查看、服务管理、注册表修改等各种操作。其次，访问是否具有隐蔽性。通过远程控制软件对主机进行远程访问时，被访问主机的任务栏或者系统托盘等区域通常会有明显的图标标识，表明有用户正在进行远程访问。如果计算机旁有用户在操作计算机，用户能够实时了解到发生了远程访问事件。而对于远程控制型木马，必须考虑到一旦计算机用户发现自己的主机感染木马，会采用各种手段进行清除，黑客很可能丧失对主机的控制，所以隐蔽性对于远程控制型木马而言非常重要。

3. 简述黑客利用远程控制型木马进行网络入侵的六个步骤。

答：配置木马、传播木马、运行木马、信息反馈、建立连接和远程控制。

4. 远程控制型木马采用反向连接技术有何优点？

答：木马采用反向连接技术除了可以解决内网 IP 地址和动态 IP 地址所带来的连接问题之外，还有一个很重要的优点是可以绕过防火墙的限制。

5. 木马在存储时可以采用哪些技术增强其隐蔽性？

答：隐藏已知文件类型的扩展名；利用文件的“隐藏”属性进行隐藏；木马可以利用系统中的一些特定文件夹（如回收站、控制面板等）实现自身的隐藏。

6. 简述木马可以采用哪些手段实现进程的隐藏？

答：1) 进程列表欺骗（在任务栏中隐藏或在任务管理器中隐藏）；

2) 不使用进程，包括：

a. Rundll32 xxx.dll 方式；

b. 特洛伊 DLL；

c. 动态嵌入技术，包括：窗口 Hook；挂接 API；远程线程注入。

7. 简述普通计算机用户如何防范主机感染木马程序。

答：安装杀毒软件，提高安全防范意识。

8. 如何将木马传播到目标主机中？

答：1) 攻击植入；

2) 伪装和欺骗植入：捆绑，邮件附件，聊天工具，木马网页；

3) 自动传播植入：邮件列表，共享磁盘，共享空间（聊天室，P2P 等）。

四、综合题

1. 在某攻防项目中需要设计一个运行于 Windows 系统的木马，有哪些方法将木马植入攻击目标？木马有哪些技术可以用来隐藏自己。

答：主要生存方法有：进程隐藏和通信隐藏。

木马的进程隐藏技术有以下几种：

1) 进程列表欺骗（在任务栏中隐藏或在任务管理器中隐藏）；

2) 不使用进程，包括：

a. Rundll32 xxx.dll 方式；

b. 特洛伊 DLL；

c. 动态嵌入技术，包括：窗口 Hook；挂接 API；远程线程注入。

木马的通信隐藏技术：

1) 使用 ICMP 协议进行通信；

2) 端口复用。

向目标植入开发的木马的技术有：

- 1) 攻击植入；
- 2) 伪装和欺骗植入：捆绑，邮件附件，聊天工具，木马网页；
- 3) 自动传播植入：邮件列表，共享磁盘，共享空间（聊天室，P2P 等）。

8.6 习题

一、单项选择题

1. 现有研究表明，人类构建的口令服从（ C ）。
A. 正态分布 B. 均匀分布 C. Zipf 分布 D. 随机分布
2. 2014 年 12 月 25 日，12306 网站部分用户信息在因特网上疯传，黑客获得这些用户信息的最可能方式是（ A ）。
A. 撞库 B. 洗库 C. 12306 网站管理员故意泄密 D. 钓鱼邮件
3. 下列国民口令中，对于中文网民而言破解较容易，而对英文网民而言破解难度较大的是（ B ）。
A. 123456 B. woaini1314 C. 111111 D. 123123
4. 如果一个网站中有高达 99.5 % 的用户口令由字母和数字共同构成，就意味着该网站在运行不久就执行了（ C ）的口令策略。
A. 随机无限制 B. 字母 + 特殊字符 C. 数字 + 字母 D. 数字 + 特殊字符
5. 如果一个网站的口令数据库中，长度为 11 位数字串的用户口令中，有大量的口令包含手机号，则这个网站很可能是（ B ）。
A. 英文网站 B. 中文网站 C. 法语网站 D. 阿拉伯语网站
6. 英文网站 Rootkit 用户的口令使用个人信息相较于中文网站 12306 的用户口令要少很多，最可能的原因是（ D ）。
A. 中文用户更倾向于在口令中使用个人信息
B. 英文用户的安全意识强
C. 只是一种偶然现象，没什么规律
D. Rootkit 网站是黑客论坛，用户的安全意识强且具有更丰富的安全专业知识
7. 下列口令攻击算法中，需要使用用户个人信息的是（ C ）。
A. PCFG 漫步攻击算法 B. Markov 漫步攻击算法
C. Targeted-Markov 算法 D. 穷举攻击
8. 下列身份认证方法中，简单易实现、成本较低的认证方法是（ A ）。
A. 静态口令认证 B. 用户特征认证 C. 密码学认证 D. 信物认证
9. 利用掌握的某网络应用账号的用户名和口令，在互联网上尝试登录其它网络应用的行为称为（ A ）。
A. 撞库 B. 洗库 C. 脱库 D. 解库
10. 下列方法中，用于自动化检测口令文件或数据库泄露的方法是（ D ）。
A. IDS B. Honeybot C. Honeynet D. Honeywords

二、简答题

1. 分析口令认证、信物认证、地址认证、用户特征认证和密码学认证的优缺点。
答：略。参考 8.1 节。
2. 分析静态口令的安全威胁。
答：（1）口令监听；（2）截取/重放；（3）穷举攻击；简单口令猜测；字典攻击；伪造服务器攻击；（7）口令泄露；（8）直接破解系统口令文件。
3. 从攻击者的角度来详细说明 N-S 协议中，为什么必须增加第(4)和第(5)步。
答：防重放攻击。
4. 简述 S/KEY 协议的小数攻击原理。
答：小数攻击的基本原理是：① 当用户向服务器请求认证时，攻击者截取服务器传给用户的种子和迭代值，并将迭代值改为较小的值；② 然后，假冒服务器，将得到的种子和

较小的迭代值发送给用户；③ 用户利用种子和迭代值计算一次性口令，发送给服务器；④ 攻击者再次截取用户传过来的一次性口令，并利用已知的散列函数依次计算较大迭代值的一次性口令，就可获得该用户后续的一系列口令，从而在一段时间内冒充合法用户而不被发现。

5. 在集中式对称密钥分配协议 Needham—Schroeder 中，什么是通信方 A、B 的主密钥？这些主密钥和会话密钥 K_s 各有什么用途？主密钥如何进行安全分配？会话密钥如何进行安全分配？

答：1) 通信方的主密钥：每个通信方和 KDC 共享的密钥，如 K_a 、 K_b ，用于用户和 KDC 的通信。

2) 会话密钥 K_s ：通信双方进行某次会话时用于加解密会话内容时共享的对称密钥。

3) 主密钥：通过带外分配的，如用户 A 到 KDC 中心申请。

4) 会话密钥：KDC 用主密钥对会话密钥加密，并分发到通信双方。

6. S/KEY 是一种一次性口令技术，回答以下问题：

1) 它是基于时间同步或事件同步的认证技术吗？那它是哪种认证技术？

2) 它能实现双向鉴别还是单向鉴别？是哪方对哪方的鉴别？

答：1) S/KEY 不是基于时间同步和事件同步的认证技术。它是挑战/应答式的非同步认证技术。2) 它能实现单向鉴别。是服务器对客户的鉴别。

7. 设计一个破解某公网用户邮箱 wangxiaodong@163.com 密码的方案。

答：答案不唯一，合理即可。例如：撞库，给邮箱发钓鱼邮件，在线口令猜测等。

8. 搜集并分析近年来发生的有影响力的脱库、洗库、撞库事件。

答：略。

9. 设计一个安全的口令有哪些原则？

答：略。参考 8.5 节。

10. 设计需要输入图形识别码的网站注册用户口令的破解方案。

答：答案不唯一，合理即可。一种可行的方案是：建立一个网站，以有奖破解的方式发动网民在线即时识别图形识别码。

11. 分析用身份证、生日、手机号码、固定电话号码等个人信息作为口令的安全性。

答：略。参考 8.2.1、8.2.2 节。

12. 简要介绍 Windows 10 操作系统的口令机制以及可能的破解方法。

答：略。参考 8.3.1 节，并查阅 Windows 10 相关手册。

13. 简要介绍 Linux 操作系统的口令机制以及可能的破解方法。

答：略。参考 8.3.2 节。

9.6 习题

一、单项选择题

1. 网卡工作在（ B ）模式时，对于接收到的数据帧，不会检查其帧头信息，而是一律产生硬件中断，通知操作系统进行处理。

- A. 正常 B. 混杂 C. 加密 D. 杂凑

2. 主机网卡在正常工作时，会接收目的 MAC 地址为（ A ）的数据帧。

- A. 本机 MAC 地址和广播地址 B. 网关 MAC 地址和广播地址
C. 本机 MAC 地址和网关 MAC 地址 D. 任意主机的 MAC 地址

3. 在交换式网络环境中，网络管理员通常通过（ A ）技术实施网络监听。

- A. 端口镜像 B. MAC 攻击 C. 端口盗用 D. ARP 欺骗

4. 虚假的 MAC 地址记录充满了交换机的 MAC 地址表，这是（ B ）攻击的表现形式。

- A. 端口镜像 B. MAC 攻击 C. 端口盗用 D. ARP 欺骗

5. ARP 木马利用感染主机向网络发送大量虚假 ARP 报文，导致网络访问不稳定。例如：向被攻击主机发送的虚假 ARP 报文中，源 IP 地址为（ A ），源 MAC 地址为（ D ）。这样会将同网段内其他主机发往网关的数据引向发送虚假 ARP 报文的机器，并抓包截取用户口令信息。

- A. 网关 IP 地址 B. 感染木马的主机 IP 地址
C. 网关 MAC 地址 D. 感染木马的主机 MAC 地址

6. 为了防御网络监听，最常用的方法是（ B ）。

- A. 采用物理传输（非网络） B. 信息加密 C. 无线传输 D. 使用专线传输

7. 网络监听的主要攻击目标是通信的（ A ）。

- A. 机密性 B. 可用性 C. 完整性 D. 可控性

8. 在某学校网络安全课程实验“Windows 环境下安装和使用 Wireshark”实施过程中，很多同学发现自己用 Wireshark 可以抓到使用 WebMail 登录学校邮箱时输入的用户名和口令，但却看不到登录 QQ 邮箱时输入的用户名和口令，最可能的原因是（ A ）。

- A. QQ 邮箱服务器只允许 HTTPS 协议登录
B. 学校邮箱服务器只允许 HTTPS 协议登录
C. Wireshark 安装或使用方法不对
D. QQ 邮箱服务器只允许 HTTP 协议登录

9. 为了实现网络监听，需要将网卡置为（ A ）。

- A. 混杂模式 B. 广播模式 C. 单播模式 D. 正常模式

10. 如果攻击者要利用 ARP 欺骗成功地实现中间人攻击，必须（ C ）。

- A. 只需污染发送者的 ARP 缓存
B. 只需污染接收者的 ARP 缓存
C. 必须同时污染发送者和接收者的 ARP 缓存
D. 污染发送者的 ARP 缓存或污染接收者的 ARP 缓存

二、多项选择题

1. 在交换式网络环境中，攻击者可以通过（ ABCD ）等技术实施网络流量劫持。

- A. 端口镜像 B. MAC 攻击 C. 端口盗用 D. ARP 欺骗

2. 攻击者无法窃听其通信内容的协议包括（ BCD ）。

- A. HTTP B. IPsec C. TLS D. HTTPS

3. 下列网络攻击行为中，破坏通信的机密性的有（ AD ）。

- A. 网络监听 B. 中断 C. 伪造 D. 通信量分析
4. 下列措施中, (AB) 可用于防范中间人网络监听。
- A. 交换机端口绑定 B. 通信加密 C. 授权 D. 认证
5. 为了监听 Wi-Fi 通信, 攻击者可采用的方法包括 (BC)。
- A. ARP 欺骗 B. 无线热点钓鱼
- C. 破解无线路由器的后台管理员口令 D. DNS 劫持

三、简答题

1. 请简述黑客采用网络监听技术能够获取哪些信息?

答: 通信内容。如果是明文传输, 则可以监听到用户名、口令等敏感信息。

2. 请简述网卡对于接收到的数据帧进行处理的具体流程。

答: 略。参考图 9-16。

3. 如何在以太网中实施网络监听?

答: 将网卡设置成混杂模式, 利用监听软件进行监听。

4. 在交换式环境中进行网络监听与在共享式网络环境中进行网络监听相比, 两者有何差异?

答: 共享式网络环境中监听不需要进行流量劫持, 而交换式环境中需要将流量劫持到监听者的主机上来。劫持方法主要有: 端口镜像、MAC 攻击、端口盗用、ARP 欺骗等。

5. 如何采用端口镜像的方法在交换式环境中实施网络监听?

答: 利用交换机提供的端口镜像功能将交换机一个或多个端口接收或发送的数据帧完全相同的复制给指定的一个或多个端口, 其中被复制的端口称为镜像源端口, 而复制操作的目的端口称为镜像目的端口。监听者主机的网络连接到镜像目的端口上。

6. MAC 攻击针对交换机的 MAC 地址表进行, 请简述这种攻击技术的实现方法。

答: 持续发送大量源 MAC 地址为随机值的数据帧, 虚假的 MAC 地址记录信息将不断增加到交换机的 MAC 地址表中, 因此这种攻击也称为“MAC 冲刷”。由于交换机 MAC 地址表中都是虚假的记录, 当有数据帧需要发送时, 交换机无法通过 MAC 地址表找到数据帧目的 MAC 对应的端口, 此时交换机只能采用洪泛的方法, 向所有物理端口转发数据帧。

7. 请简述 ARP 病毒伪装成网关以中间人的形式实施网络监听的具体流程。

答: 略。参考 9.2.1 节。

8. 为了防范网络中有主机实施网络监听, 可以采用哪些技术手段。

答: (1) 从逻辑或物理上对网络分段; (2) 交换机端口绑定; (3) 采用加密技术; (4) 防范与网络监听的有关的黑客技术。

9. 简述 ARP 欺骗的基本原理。

答: ARP 欺骗, 或者称为 ARP 缓存中毒, 是指使用错误的 IP-MAC 映射刷新主机的 ARP 缓存。ARP 缓存中毒使得受害者将报文发往错误的 MAC 地址, 因而可能导致主机不能够正常通信。如果攻击者同时对修改通信的双方的 ARP 缓存则可能导致中间人攻击。

10. 假定某局域网中, 主机 A 的 IP 地址是 192.168.1.1, MAC 地址是 aa:bb:cc:dd:ee:01, 主机 B 的 IP 地址是 192.168.1.2, MAC 地址是 aa:bb:cc:dd:ee:02, 攻击者的 IP 地址是 192.168.1.3, MAC 地址是 aa:bb:cc:dd:ee:03。如果攻击者想通过 ARP 欺骗监听主机 A 和主机 B 之间的通信, 他应该向主机 A 和主机 B 发送什么报文 (要求写出报文的关键内容)。

答: 攻击者向 A 发送 ARP 响应或者 ARP 请求报文, 报文内容的核心是将 192.168.1.2 的 IP 对应于 MAC 地址: aa:bb:cc:dd:ee:03, 向 B 发送 ARP 响应或者 ARP 请求报文, 报文内容的核心是将 192.168.1.1 的 IP 对应于 MAC 地址: aa:bb:cc:dd:ee:03。由于按照 ARP 协议, 主机不会进行任何验证即更新自己的 ARP 缓存, 主机 A、B 会将错误的 IP-MAC 映射

保存到自己的 ARP 缓存当中。

10.5 习题

一、单项选择题

1. 下列进程的内存区域中, 不会发生缓冲区溢出的是 (D)。
A. 堆 (Heap) B. 堆栈 (Stack) C. 静态数据段 (BSS) D. 文本段 (Text)
2. 堆栈之所以能够发生溢出, 一个重要的原因是 (A)。
A. 栈是向低地址方向增长 B. 栈是向高地址方向增长
C. 栈底在内存低端 D. 栈顶是在内存高端
3. 如果要利用缓冲区溢出漏洞, 必须要做的工作是 (B)。
A. 在程序中植入攻击代码 B. 改变程序的执行流程
C. 在程序中植入攻击参数 D. 同时在程序中植入攻击代码和攻击参数
4. 如果堆栈不可执行, 则为了利用堆栈溢出漏洞, 首先必须 (C)。
A. 在程序中植入攻击代码 B. 改变程序的执行流程
C. 在程序中植入攻击参数 D. 同时在程序中植入攻击代码和攻击参数
5. 通过 malloc 类函数分配的内存来自于 (A)。
A. 堆 B. 堆栈 C. 文本段 D. 静态数据段

二、简答题

1. 简要描述 Windows 系统中的进程内存布局, 并分析这种布局有什么安全缺陷。

答: 略。参考图 10-1。栈的增长方向是从内存高端向内存低端增长 (栈底在内存高端, 栈顶在内存低端), 而大多数的内存拷贝是从内存低端到内存高端, 这为栈溢出提供了条件。

2. 举例说明堆栈溢出攻击原理及防范措施。

答: 略。参考图 10-3。

3. 举例说明堆溢出攻击原理。

答: 略。参考 10.2.3 节。

4. 举例说明 BSS 段溢出攻击的原理。

答: 略。参考 10.2.4 节。

5. 如何防范缓冲区溢出攻击?

答: 略。参考 10.3 节。

6. 图示说明下述程序堆栈的变化过程, 并在 VC 开发环境下进行验证。

```
void function(char *buf_src, int i)
{
    char buf_dest[54];
    printf("i=%d", i);
    strcpy(buf_dest, buf_src);
}

void main(int argc, char **argv)
{
    int k;
    char str[128];
    for( k = 0; k<126; k++) str[k] = 'b';
    str[127]='\0';
    function(str);
}
```

答: 略。

堆栈变化流程:

在main函数中, 创建了一个128字节的字符串str, 填充了126个'b'字符和一个空字符'\0'
调用function函数, 并将str作为参数传递。

栈帧变化:

function函数中定义了一个54字节的buf_dest数组。

strcpy将str复制到buf_dest, 由于str的长度超过了buf_dest的大小, 导致缓冲区溢出。

printf输出:

输出i的值, 由于i未初始化, 输出不确定。

溢出结果:

buf_dest被str的内容溢出, 可能会覆盖相邻的内存, 包括函数的返回地址。

7. 编写一段可用于 Windows 7 平台下的 shellcode, 其功能是获取一个命令窗口(cmd)。

答: 略。参考 10.2.2 节的例子。

11.11 习题

一、单项选择题

1. 为提高 Cookie 的安全性，不建议采取的策略是（ C ）。
A. 在 Cookie 中设置 secure 属性
B. 在 Cookie 中不设置 domain 属性
C. 在 Cookie 中设置 domain 属性
D. 将 Cookie 的生存周期设置为 0 或负值
2. 下列选项中，（ B ）不属于 Web 应用在输出过程中产生的安全漏洞。
A. SQL 注入 B. CSRF C. HTTP 头注入 D. OS 命令注入
3. 在 Web 用户登录界面上，某攻击者在输入口令的地方输入 'or'a'='a' 后成功实现了登录，则该登录网页存在（ A ）漏洞。
A. SQL 注入 B. CSRF C. HTTP 头注入 D. XSS
4. 为了防范跨站脚本攻击（XSS），需要对用户输入的内容进行过滤，下列字符中，不应被过滤的是（ D ）。
A. < B. > C. ' D. o
5. 下列 Web 应用攻击方法中，不属于跨站被动攻击的是（ C ）。
A. CSRF B. XSS C. SQL 注入 D. HTTP 头注入
6. 利用已登录网站的受信任用户身份来向第三方网站发送交易转账请求的攻击方法是（ A ）。
A. CSRF B. XSS C. SQL 注入 D. HTTP 头注入
7. 下列方法中，不能防止 CSRF 攻击的是（ D ）。
A. 嵌入令牌 B. 再次输入密码
C. 校验 HTTP 头中的 Referer D. 过滤特殊字符
8. 下列选项中，不属于目录遍历漏洞的必要条件是（ B ）。
A. 外界能够指定文件名
B. 设置 Cookie 中的 secure 属性
C. 能够使用绝对路径或相对路径等形式来指定其它目录的文件名
D. 没有对拼接后的文件名进行校验就允许访问该文件
9. 可污染缓存服务器的 Web 攻击方法是（ C ）。
A. SQL 注入 C. 操作系统命令注入 C. HTTP 消息头注入 D. XSS
10. 下列选项中，不能消除操作系统命令注入漏洞的是（ A ）。
A. 使用 HTTPS
B. 不调用 Shell 功能
C. 避免使用内部可能会调用 Shell 的函数
D. 不将外部输入的字符串作为命令行参数
11. 某单位联在公网上的 Web 服务器的访问速度突然变得比平常慢很多，甚至无法访问到，这台 Web 服务器最有可能遭到的网络攻击是（ A ）。
A. 拒绝服务攻击
B. SQL 注入攻击
C. 木马入侵
D. 缓冲区溢出攻击
12. 某单位联在公网上的 Web 服务器经常遭受到网页篡改、网页挂马、SQL 注入等黑客攻击，请从下列选项中为该 Web 服务器选择一款最有效的防护设备（ C ）。
A. 网络防火墙 B. IDS C. WAF D. 杀毒软件

13. Web 浏览器和服务端使用 HTTPS 协议，而不是 HTTP 协议进行通信，不能确保通信的（ C ）。

A. 机密性 B. 完整性 C. 可靠性 D. 服务器的真实性

二、简答题

1. 简要分析 Web 应用体系的脆弱性。

答：从客户端的脆弱性、Web 服务器的脆弱性、Web 应用程序的脆弱性、HTTP 协议的脆弱性、Cookie 的脆弱性、数据库脆弱性等几个方面进行论述。具体描述参考 11.2 节。

2. 简述 SQL 注入攻击漏洞的探测方法。

答：略。参考 11.3.2 节。

3. 如果你是一个 Web 应用程序员，应该采取哪些措施减少 Web 应用程序被 SQL 注入攻击的可能性？

答：对用户输入进行检查，确保用户输入数据的安全性。在检查用户输入或提交的变量时，根据参数的类型，可对单引号、双引号、分号、逗号、冒号、连接号等进行转换或过滤，这样就可以防止很多 SQL 注入攻击；在构造动态 SQL 语句时，一定要使用类安全(type-safe)的参数编码机制；禁止将敏感性数据以明文存放在数据库中，这样即使数据库被 SQL 注入漏洞攻击，也会减少泄密的风险；遵循最小特权原则；尽量不要使用动态拼装的 SQL，可以使用参数化的 SQL 或者直接使用存储过程进行数据查询存取；应用的异常信息应该给出尽可能少的提示。

4. 简述 XSS 攻击的前提条件。

答：进行 XSS 攻击需要两个前提：第一，Web 程序必须接受用户的输入，这显然是必要条件，输入不仅包括 URL 中的参数和表单字段，还包括 HTTP 头部和 Cookie 值；第二，Web 程序会重新显示用户输入的内容，只有用户浏览器将 Web 程序提供的数据解释为 HTML 标记时，攻击才会发生。

5. 简述反射式跨站脚本攻击、储存式跨站脚本攻击、DOM 式跨站脚本攻击的区别。

答：略。参考 11.4.1 节。

6. 如何判断一个网站上是否存在跨站脚本漏洞？

答：查看代码，具体判断方法与 XSS 漏洞类型相关，参考 11.4.1 节；用工具测试。

7. 如果想进入某网站管理后台，可采取哪些攻击方法？

答：答案不唯一，合理即可。例如 SQL 注入，远程口令猜测，利用 Cookie 等。

8. 如何将 Cookie 攻击和 XSS 攻击相结合对指定网站进行攻击？

答：答案不唯一，合理即可。

9. 简述 CSRF 攻击与 XSS 攻击的区别与联系。

答：CSRF 与 XSS 的差别在于：XSS 利用的是网站内的信任用户，而 CSRF 则是通过伪装来自受信任用户的请求来利用受信任的网站。

10. 简述目录遍历攻击原理及防御措施。

答：如果 Web 应用满足以下 3 个条件，就有可能产生目录遍历漏洞：

- (1) 外界能够指定文件名；
- (2) 能够使用绝对路径或相对路径等形式来指定其它目录的文件名；
- (3) 没有对拼接后的文件名进行校验就允许访问文件。

防御措施：1) 避免由外界指定文件名；2) 文件名中不允许包含目录名；3) 限定文件中仅包含字母或数字。

11. 什么条件下会产生操作系统命令注入漏洞？如果应对这种攻击？

答：Web 应用通过 Shell 执行 OS 命令，或开发中用到的某个方法在其内部使用 Shell，

就有可能出现恶意利用 Shell 提供的功能来执行任意 OS 命令的情况。

防御 OS 命令注入的策略一般包括以下几种：

- (1) 选择不调用操作系统命令的实现方法，即不调用 Shell 功能，而用其它方法实现；
- (2) 避免使用内部可能会调用 Shell 的函数；
- (3) 不将外部输入的字符串作为命令行参数；
- (4) 使用安全的函数对传递给操作系统的参数进行转义，消除 Shell 元字符带来的威胁。

12. 如何防御 HTTP 消息头注入攻击？

答：

- (1) 不将外部传入参数作为 HTTP 响应消息头输出，如不直接使用 URL 指定重定向目标，而是将其固定或通过编号等方式来指定，或使用 Web 应用开发工具中提供的会话变量来转交 URL；
- (2) 由专门的 API 进行重定向或生成 Cookie，并严格检验生成消息头的参数中的换行符。

13. 简述 Web 应用防火墙的工作原理。

答：对每一个 HTTP/HTTPS 请求进行内容检测和验证，确保每个用户请求有效且安全的情况下才交给 Web 服务器处理，对非法的请求予以实时阻断或隔离、记录、告警等。

WAF 主要提供对 Web 应用层数据的解析，对不同的编码方式做强制多重转换还原为可分析的明文，对转换后的消息进行深度分析。主要的分析方法有两类，一类是基于规则的分析方法，另一类是异常检测方法。

12.5 习题

一、单项选择题

1. 下列攻击方法中，属于社会工程攻击的是（ B ）。
A. SQL Injection B. 钓鱼邮件 C. TCP 连接劫持 D. 网络扫描
2. 社会工程攻击主要针对的是（ A ）。
A. 人的脆弱性 B. 入侵检测系统的脆弱性
C. 防火墙的脆弱性 D. 系统维护的脆弱性
3. 下列工具中，主要用于社会工程攻击的是（ D ）。
A. Nmap B. Nessus C. Traceroute D. SET
4. 很多 APT 攻击组织常用热点新闻事件或敏感话题作为钓鱼邮件的内容，这种社会工程学方法属于（ B ）。
A. 伪装 B. 引诱 C. 说服 D. 恐吓
5. 社会工程学攻击一般需要借助大量的情报数据来实施，这些数据通常称为（ A ）。
A. 社工库 B. 数据库 C. 情报 D. 信息

二、多项选择题

1. 下列选项中，常用来进行 URL 伪装的组合包括（ ABC ）。
A. 英文字母 o 和数字 0 B. 英文字母 a 和俄文字母 а
C. 英文字母 l 和数字 1 D. 英文字母 h 和 k
2. 下列文字中，常被社会工程人员制作钓鱼网站时用来在 URL 中替换特定英文字母的有（ BC ）。
A. 中文 B. 西里尔文 C. 俄文 D. 日文
3. 利用社会工程工具 SET，可以直接实现的功能有（ BCD ）。
A. 漏洞攻击 B. 制作钓鱼网站 C. 制作钓鱼邮件 D. 群发邮件
4. 如果用户收到一封冒充邮箱管理员发送的安全警告邮件，提醒用户其口令已泄露，点击按钮修改口令，则这种社会工程学方法属于（ AD ）。
A. 伪装 B. 引诱 C. 说服 D. 恐吓
5. 下列攻击中，利用人的弱点的攻击有（ BCD ）。
A. 窃听 B. 钓鱼短信 C. 钓鱼邮件 D. 同学聚会合影邮件

三、简答题

1. 收集或自己设计伪装、引诱、恐吓、说服、反向社会工程等社会工程攻击案例各一例，并进行简要分析。
答：略。
2. 简述 1.4.1 节介绍的各个网络安全模型中是否考虑了“人”的因素，如果有，是如何体现的。
答：略。
3. 谈谈你对“自认为最安全的人恰恰常常会带来最大的安全漏洞。”的理解，并举例说明。
答：略。答案不唯一，合理即可。
4. 分析“主题乐园”案例的经验教训。
答：略。答案不唯一，合理即可。
5. 分析“过于自信的 CEO”案例中攻击者采用了哪些社会工程攻击方法，并总结这个案例的经验教训。

答：略。答案不唯一，合理即可。

6. 分析“让用户安装木马”案例，为企业员工制定一套安全培训计划（只需写出安全培训内容）。

答：略。答案不唯一，合理即可。

7. 简述社会工程学攻击工具 SET 的主要功能。

答：略。参考 12.3 节。

8. 简述社会工程学攻击防范措施。

答：略。答案不唯一，合理即可。参考 12.4 节。

9. 谈谈你对“不要让‘人之间的关系’问题介入到你的信息安全链路之中”的理解。

答：略。答案不唯一，合理即可。

13.7 习题

一、单项选择题

1. 在防火墙技术中，我们所说的外网通常指的是（ B ）。
A. 受信任的网络 B. 非受信任的网络 C. 防火墙内的网络 D. 局域网
2. 下面关于防火墙策略说法正确的是（ C ）。
A. 在创建防火墙策略以前，不需要对企业那些必不可少的应用软件执行风险分析
B. 防火墙安全策略一旦设定，就不能再作任何改变
C. 防火墙处理入站通信的默认策略应该是阻止所有的包和连接，除了被指出的允许通过的通信类型和连接
D. 防火墙规则集与防火墙平台体系结构无关
3. 包过滤型防火墙主要作用在（ C ）。
A. 网络接口层 B. 应用层 C. 网络层 D. 数据链路层
4. 应用网关防火墙主要作用在（ D ）。
A. 数据链路层 B. 网络层 C. 传输层 D. 应用层
5. 下列关于防火墙的说法，错误的是（ C ）。
A. 防火墙的核心是访问控制
B. 防火墙也有可能被攻击者远程控制
C. 路由器中不能集成防火墙的部分功能
D. 如果一个网络没有明确边界，则使用防火墙可能没效果
6. 在设计防火墙时，考虑内网中需要向外提供服务的服务器常常放在一个单独的网段，这个网段称为（ D ）。
A. RSA B. DES C. CA D. DMZ
7. 四种防火墙结构中，相对而言最安全的是（ D ）。
A. 屏蔽路由器结构 B. 屏蔽主机结构 C. 双宿主主机结构 D. 屏蔽子网结构
8. 某单位联在公网上的 Web 服务器经常遭受到网页篡改、网页挂马、SQL 注入等黑客攻击，请从下列选项中为该 Web 服务器选择一款最有效的防护设备（ C ）。
A. 网络防火墙 B. IDS C. WAF D. 杀毒软件
9. 配置防火墙时，不正确的观点是（ A ）。
A. 可以不考虑防火墙过滤规则的顺序
B. 没有明确允许的就是禁止的
C. 防火墙过滤规则的顺序与安全相关
D. 根据需要可以允许从内部站点访问 Internet 也可以从 Internet 访问内部站点
10. 很多单位的安全管理员会因为安全的原因禁用因特网控制管理协议（ICMP），则他可以使用网络安全设备（ B ）来实现。
A. 杀毒软件 B. 防火墙 C. 入侵检测系统 D. 网络扫描软件
11. 下列防火墙部署模式中，可隐藏内网 IP 地址的是（ C ）。
A. 透明模式 B. 网关模式 C. NAT 模式 D. 桥接模式
12. 方程式组织武器库中的 EXBA 工具利用 Cisco 防火墙的一个零日漏洞（CVE-2016-6366）实现对 Cisco 防火墙的远程控制。攻击成功的前提是目标防火墙中必启用（ D ）。
A. FTP 服务 B. 包过滤服务 C. VPN 服务 D. SNMP 服务

二、多项选择题

1. 配置防火墙时，错误的原则是（ AD ）。
A. 允许从内部站点访问 Internet 而不允许从 Internet 访问内部站点

- B. 没有明确允许的就是禁止的
- C. 防火墙过滤规则的顺序与安全密切相关
- D. 可以不考虑防火墙过滤规则的顺序
- 2. 下列安全机制中，可用于机密性保护的有（ AB ）。
- A. 加密 B. 防火墙 C. 入侵检测 D. 数字签名
- 3. 下列关于防火墙的说法中，正确的是（ ABCD ）。
- A. 防火墙并不能阻止所有的网络攻击
- B. 防火墙自身可能存在安全漏洞导致攻击者可以绕过防火墙
- C. 如果防火墙配置不当，可能会起不到预期的防护作用
- D. 攻击流量不经过防火墙，而是通过无线接入单位内网，防火墙无法进行控制
- 4. 下列系统或设备中，（ BCD ）采用访问控制机制来实现对资源的安全访问。
- A. 加密系统 B. 防火墙 C. 操作系统 D. 数据库
- 5. 防火墙的安全漏洞可能存在于（ ABCD ）。
- A. 设计上 B. 安全策略的配置上 C. 防火墙软件的实现上 D. 硬件平台
- 6. 下列防火墙部署模式中，可提供路由功能的是（ BC ）。
- A. 透明模式 B. 网关模式 C. NAT 模式 D. 桥接模式
- 7. 下列说法正确的是（ ABC ）。
- A. 路由器可以集成防火墙功能
- B. 防火墙可以实现 VPN
- C. 防火墙可以实现路由功能
- D. 防火墙可以阻止内网用户泄密
- 8. 从攻击者的角度看，为了提高成功率，可以采用（ AB ）等方法穿过防火墙。
- A. 将攻击数据包隐藏在 HTTPS 流量中
- B. 将攻击数据包的 TCP 目的端口设置成 80
- C. 将攻击数据包的 TCP 目的端口设置成 5480
- D. 将攻击数据包隐藏在 ICMP 协议流量中

三、问答题

1. 防火墙部署在网络边界所起到的安全防护作用主要体现在哪些方面？

答：保护内网中脆弱以及存在安全漏洞的网络服务；实施安全策略，对网络通信进行访问控制；防止内网信息暴露；对内外网之间的通信进行监控审计。

2. 网络级防火墙通常是具有特殊功能的路由器，这类路由器与一般路由器主要有哪些区别？

答：差别在于是否对路由的数据包进行安全检测。

3. 请简述包过滤防火墙是如何工作的。

答：略。参考 13.2.1 节。

4. 包过滤防火墙的运作通常需要满足哪些基本要求？

答：6 项基本要求：1) 包过滤防火墙必须能够存储包过滤规则；2) 当数据包到达防火墙的相应端口时，防火墙能够分析 IP、TCP、UDP 等协议报文头字段；3) 包过滤规则的应用顺序与存储顺序相同；4) 如果一条过滤规则阻止某个数据包的传输，那么此数据包便被防火墙丢弃；5) 如果一条过滤规则允许某个数据包的传输，那么此数据包可以正常通行；6) 从安全的角度出发，如果某个数据包不匹配任何一条过滤规则，那么该数据包应当被防火墙丢弃。

5. 包过滤防火墙在安全防护方面有哪些优点和缺点。

答：优点：首先，将包过滤防火墙放置在网络的边界位置，即可以对整个网络实施保护，简单易行；其次，包过滤操作处理速度快、工作效率高，对正常网络通信的影响小；第三，包过滤防火墙对用户和应用都透明，内网用户无需对主机进行特殊设置。

缺点：首先，包过滤防火墙主要依赖于对数据包网络层和传输层首部信息的判定，不对应用负载进行检查，判定信息的不足使其难以对数据包进行细致的分析。其次，包过滤防火墙的规则配置较为困难，特别是对于安全策略复杂的大型网络，如果包过滤规则配置不当，防火墙难以有效的进行安全防护。第三，包过滤防火墙支持的规则数量有限，如果规则过多，数据包依次与规则匹配，将降低网络效率。最后，由于数据包中的字段信息容易伪造，攻击者可以通过 IP 欺骗等方法绕过包过滤防火墙，而包过滤防火墙本身难以进行用户身份认证，这些因素使得攻击者可能绕过包过滤防火墙实施攻击

6. 有状态的包过滤防火墙相比于无状态的包过滤防火墙有哪些优点？

答：有状态的包过滤防火墙在接收到数据包时，将以连接状态表为基础，依据配置的包过滤规则，判断是否允许数据包通过，从而更加有效地保护网络安全；有状态的包过滤防火墙能够提供更全面的日志信息。

7. 应用网关防火墙有哪些优点和缺陷？

答：优点：应用网关防火墙由于理解应用协议，能够细粒度的对通信数据进行监控、过滤和记录。此外，可以通过应用网关防火墙对用户身份进行认证，确保只有允许的用户才能通过。

缺点：①每种应用服务需要专门的代理模块进行安全控制，而不同应用服务采用的网络协议存在较大差异，例如 HTTP 协议、FTP 协议、Telnet 协议，不能采用统一的方法进行分析，给代理模块的实现带来了很大困难。实际应用中，大部分代理服务器只能处理相对较少的应用服务；②从性能上看，应用网关防火墙的性能往往弱于包过滤防火墙；③从价格上看，应用网关防火墙通常比包过滤防火墙更为昂贵，因为应用网关防火墙对硬件设备有更高的要求；④从配置和管理的复杂性看，应用网关防火墙需要针对应用服务类型逐一设置，而且管理员必须对应用协议有深入理解，管理的复杂性较高。

8. 防火墙的屏蔽子网结构通常包括哪些部分，为什么说这种结构具有很高的安全性？

答：包括：DMZ 区（外部包过滤防火墙、堡垒主机、内部包过滤防火墙）、内网。对于屏蔽子网结构，黑客要侵入内网，必须攻破外部包过滤防火墙，设法侵入 DMZ 区的堡垒主机。由于内网中主机之间的通信不经过 DMZ 区，因此，即使黑客侵入堡垒主机，也无法获取内网主机间的敏感通信数据。黑客只有控制内部包过滤防火墙，才能进入内网实施破坏。

9. 防火墙产品的并发连接数主要取决于哪些因素？

答：防火墙设备内并发连接表的大小；防火墙的 CPU 处理能力；防火墙的物理链路的承载能力。

10. 防火墙技术在安全防护方面还存在哪些不足？

答：1) 防火墙的防护并不全面，不能检测所有攻击行为；2) 防火墙所发挥的安全防护作用在很大程度上取决于防火墙的配置是否正确、完善；3) 一些利用系统漏洞或者网络协议漏洞进行的攻击，防火墙难以防范，同时防火墙本身也可能存在安全漏洞；4) 防火墙不能防止病毒、木马等恶意代码的网络传输；5) 网络宽带化的进程迅速，防火墙的处理能力难以与之适应；6) 防火墙不能防止内网用户的主动泄密；7) 只能用于有明确网络边界的网络，而云计算的引入导致有些网络并不存在明确的网络边界。

四、综合题

1. 查阅近年来有关防火墙安全漏洞的相关资料，撰写一份有关防火墙自身安全问题的分析报告。

答：略。

14.8 习题

一、单项选择题

1. 基于网络的 IDS 最适合检测(C)攻击。
A. 字典攻击和特洛伊木马
B. 字典攻击和拒绝服务攻击
C. 网络扫描和拒绝服务攻击
D. 拒绝服务攻击和木马
2. 下列入侵检测方法中, (C)不是特征检测的实现方式。
A. 模式匹配法 B. 专家系统法 C. 统计分析法 D. 状态迁移法
3. 采用异常检测方法进行入侵检测时, 可以用 (A) 来评估用于异常检测的数据的质量。质量越高, 说明数据越有规律, 用其来进行异常检测就越准确。
A. 条件熵 B. 数据量 C. 数据类别 D. 概率
4. 如果要检测已知攻击, 检测准确率最高的方法是 (D)。
A. 聚类分析 B. 人工免疫 C. 神经网络 D. 模式匹配
5. 下列方法中, 适合检测未知攻击的是 (A)。
A. 异常检测 B. 特征检测 C. 专家系统 D. 模式匹配
6. Snort 软件采用的入侵检测方法属于 (B)。
A. 异常检测 B. 特征检测 C. 神经网络 D. 机器学习
7. 下列安全机制中, 兼有入侵检测和防御攻击的有 (C)。
A. 防火墙 B. 杀毒软件 C. 网络欺骗防御 D. 入侵检测系统
8. 如果攻击者使用一个零日漏洞对目标网络进行渗透攻击, 则最有可能检测并防御这种攻击的安全机制是 (C)。
A. 防火墙 B. 杀毒软件 C. 网络欺骗防御 D. 入侵检测系统
9. 如果攻击者使用加密信道 (如 IPsec, TLS, HTTPS) 对目标网络进行攻击, 则最有可能检测到这种攻击的是 (B)。
A. 基于网络的 IDS B. 基于主机的 IDS
C. 基于网络的 IDS 和基于主机的 IDS D. 防火墙
10. 如果攻击者在扫描一个网络时, 扫描到了大量活动的主机, 但在实施进一步攻击时, 却发现很多主机有些异常, 则该网络很可能采取了 (D) 防御机制。
A. 基于主机的入侵检测 B. 基于网络的入侵检测 C. 防火墙 D. 网络混淆

二、多项选择题

1. 单位网络边界处已配置了网络防火墙, 在内网中再配置入侵检测系统的主要原因包括 (ABCD)。
A. 防火墙并不能阻止所有的网络攻击
B. 防火墙自身可能存在安全漏洞导致攻击者可以绕过防火墙
C. 如果防火墙配置不当, 可能会起不到预期的防护作用
D. 攻击流量不经过防火墙, 而是通过无线接入单位内网, 防火墙无法进行控制
2. 下列数据中, 可用于判断计算机是否被入侵的有 (ABCD)。
A. 操作系统日志 B. 网络数据 C. 应用程序日志 D. 注册表记录
3. 如果要进行未知攻击检测, 则应选择 (ABC)。
A. 聚类分析 B. 人工免疫 C. 神经网络 D. 模式匹配
4. 评价入侵检测系统性能的最重要的两个指标是 (BD)。
A. 吞吐率 B. 漏报率 C. 速率 D. 误报率

5. 下列安全技术中，采用网络欺骗技术的是（ CD ）。
- A. 防火墙 B. 入侵检测 C. 蜜罐 D. 蜜网
6. 下列安全技术中，可用于检测网络攻击的有（ CD ）。
- A. 防火墙 B. VPN C. 入侵检测系统 D. 蜜网
7. 下列安全机制中，可用于引诱攻击者发起攻击的是（ BD ）。
- A. 防火墙 B. 蜜罐 C. 入侵检测系统 D. 蜜网
8. 下列选项中，属于数据层欺骗技术的是（ AC ）。
- A. Honeywords B. 协议指纹混淆 C. 诱饵文档 D. 设置大量虚假主机

三、简答题

1. 入侵检测系统对防火墙的安全弥补作用主要体现在哪些方面？

答：1) 入侵检测可以发现内部的攻击事件以及合法用户的越权访问行为，而位于网络边界的防火墙对于这些类型的攻击活动无能为力。

2) 如果防火墙开放的网络服务存在安全漏洞，入侵检测系统可以在网络攻击发生时及时发现并进行告警。

3) 在防火墙配置不完善的条件下，攻击者可能利用配置漏洞穿越防火墙，入侵检测系统能够发现此类攻击行为。

4) 对于加密的网络通信，防火墙无法检测，但是监视主机活动的入侵检测系统能够发现入侵。

5) 入侵检测系统能够有效发现入侵企图。如果防火墙允许外网访问某台主机，当攻击者利用扫描工具对主机实施扫描时，防火墙会直接放行，但是入侵检测系统能够识别此类网络异常并进行告警。

6) 入侵检测系统可以提供丰富的审计信息，详细记录网络攻击过程，帮助管理员发现网络中的脆弱点。

2. 从信息源的角度看，以操作系统的审计记录作为入侵检测的信息源存在哪些缺陷？

答：1) 不同操作系统在审计的事件类型、内容组织、存储格式等方面都存在差异，入侵检测系统如果要求跨平台工作，必须考虑各种操作系统审计机制的差异。

2) 操作系统的审计记录主要是方便日常管理维护，同时记录一些系统中的违规操作，其设计并不是为入侵检测系统提供检测依据。在这种情况下，审计记录对于入侵检测系统而言包含的冗余信息过多，分析处理的负担较重。

3) 入侵检测系统所需要的一些判定入侵的事件信息，可能操作系统的审计记录中没有提供，由于信息的缺失，入侵检测系统还必须通过其他渠道获取。

3. 以应用程序的运行记录作为入侵检测系统的信息源，对于检测针对应用的攻击活动存在哪些优势？

答：1) 精确度高。主机的审计信息必须经过一定的处理和转化之后，才能变为入侵检测系统能够理解的应用程序运行信息，而且在此转化过程中往往会丢失部分信息。直接利用应用数据，可以在最大程度上保证入侵检测系统所获得信息的精确度。

2) 完整性强。对于一些网络应用，特别是分布式的网络应用，直接通过主机的日志信息、甚至结合收集到的网络数据，都难以准确获取应用的具体状态。但是，应用数据能够最全面地反映应用的运行状态信息。

3) 采用应用数据作为入侵检测的信息源具有处理开销低的优势。主机的审计信息反映的是系统整体运行情况，要将其转化为应用信息必须经过计算处理。而应用程序日志本身就是应用层次的活动记录，可以直接向入侵检测系统提供其所关注的应用的运行状况。

4. 请分析基于网络的入侵检测系统的优点和缺点。

答：基于网络的入侵检测系统具有隐蔽性好、对被保护系统影响小等优点，同时也存在粒度粗、难以处理加密数据等方面的缺陷。

5. 什么是基于异常和基于误用的入侵检测方法？它们各有什么特点？

答：基于误用的入侵检测方法的基本思路是事先提取出描述各类攻击活动的特征信息，利用攻击特征对指定的数据内容进行监视，一旦发现攻击特征在监视的数据中出现，即判定系统内发生了相应的攻击活动。

基于异常的检测方法首先总结出正常活动的特征，建立相应的行为模式。在入侵检测的过程中，以正常的行为模式为基础进行判定，将当前活动与代表正常的行为模式进行比较，如果当前活动与正常行为模式匹配，则认为活动正常；而如果两者存在显著偏差，则判定出现了攻击。

基于误用的检测方法只能检测已知攻击，误报率低，无法检测未知攻击。基于异常的检测方法可以检测未知攻击，但误报率高。

6. 为什么说异常检测所发现的异常未必是攻击活动？

答：因为定义的正常行为不一定完备和准确，可能会造成合法的行为被认为是异常的。

7. 如何对入侵检测系统的效能进行评估。

答：误报率、漏报率、准确率。

8. 入侵检测技术主要存在哪些方面的局限性。

答：答案不唯一，合理即可。参考 14.6 节。

9. 谈谈你对蜜罐、蜜网、网络欺骗防御这三个概念的理解。

答：答案不唯一，合理即可。参考 14.7.3 节对这三个概念的关系的论述。